ETSI TS 103 732-1 V3.1.1 (2026-09)

++



TECHNICAL SPECIFICATION

Cyber Security (CYBER);
Consumer Mobile Device;
Part 1: Base Protection Profile

Reference
RTS/CYBER-00146

Keywords
cybersecurity, mobile, privacy, terminal

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° w061004871

Important notice

The present document can be downloaded from the
ETSI Search & Browse Standards application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on ETSI deliver repository.

Users should be aware that the present document may be revised or have its status changed, this information is available in the Milestones listing.

If you find errors in the present document, please send your comments to the relevant service listed under Committee Support Staff.

If you find a security vulnerability in the present document, please report it through our Coordinated Vulnerability Disclosure (CVD) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.
No recommendation as to products and services or vendors is made or should be implied.
No representation or warranty is made that this deliverable is technically accurate or sufficient or conforms to any law and/or governmental rule and/or regulation and further, no representation or warranty is made of merchantability or fitness for any particular purpose or against infringement of intellectual property rights.
In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

No part of this document may be reproduced in any form, by any means and in any media, without the prior written authorization of ETSI and except as expressly permitted below.
By way of exception and when the document is a normative deliverable (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)), ETSI authorizes to reproduce and incorporate into products, services and technical documentation only those extracts (e.g. templates) that are strictly necessary for the technical implementation of the normative deliverable, to ensure compliance with the latter.
Nothing in this notice shall be construed as limiting any mandatory exceptions to copyright provided by applicable law.

© ETSI 2026.
All rights reserved.

Contents

Intellectual Property Rights 5
Foreword 5
Modal verbs terminology 5
Introduction 6
1 Scope 7
2 References 7
2.1 Normative references 7
2.2 Informative references 9
3 Definition of terms, symbols and abbreviations 10
3.1 Terms 10
3.2 Symbols 12
3.3 Abbreviations 12
4 TOE Definition 13
4.1 TOE Overview 13
4.2 Usage and Major Security Features 14
4.3 Additional Hardware/Software/Firmware required by the TOE 17
4.4 Base-PP reference 17
4.5 Conformance Claim 17
5 Security Problem Definition 18
5.1 Assets and interfaces of the TOE 18
5.2 Threat agents and threats 19
5.3 Organizational Security Policies 20
5.4 Assumptions 20
6 Security Objectives 21
6.1 Security Objectives for the TOE 21
6.2 Security Objectives for the Operational Environment 21
6.3 Security Objectives Rationale 22
7 Extended Components Definition 23
7.1 Definition of the Class FAP: Applications 23
7.1.1 Introduction 23
7.1.2 Definition of the family Application Lifecycle (FAP_LFC_EXT) 24
7.2 Definition of the family Cryptographic Key Hierarchy (FCS_CKH_EXT) 24
7.3 Definition of the family Update Check Frequency (FDP_UPF_EXT) 25
7.4 Definition of Processed Data Minimisation (ADV_PDM_EXT) 26
7.5 Definition of the Documentation of security measures for device identifiers (ALC_DVS_EXT) 28
8 Security requirements 30
8.1 Overview 30
8.2 Conventions 30
8.3 Security functional requirements 31
8.3.1 Applications (FAP) 31
8.3.2 Cryptographic Support (FCS) 31
8.3.3 User Data Protection (FDP) 34
8.3.3.1 Monitoring 34
8.3.3.2 The Update Policy 34
8.3.3.3 The Permissions Policy 37
8.3.3.4 The Data Classification Policy 39
8.3.4 Identification and Authentication (FIA) 40
8.3.5 Security Management (FMT) 41
8.3.6 Privacy (FPR) 44
8.3.7 Protection of the TSF (FPT) 44
8.3.8 Trusted Path/Channels (FTP) 46

8.4 Security assurance requirements 47
8.4.1 Introduction....47
8.4.2 Augmented security assurance requirements 47
8.4.3 Independent testing considerations (ATE_IND.1)....49
8.4.4 Vulnerability assessment considerations (AVA_VAN.2)....49
8.5 Security requirements rationale....50
8.5.1 Rationale for choosing the SARs....50
8.5.2 The SFRs meet all the security objectives for the TOE....51
8.5.3 Dependency analysis....52

Annex A (informative): Other related specifications 55
A.1 ETSI EN 303 645....55
A.2 Void....62

Annex B (informative): Rating of a physical attack....63

Annex C: Void....64

Annex D (informative): Guidance for FTP_PRO Radio Requirements....65

D.1 Radio Requirements Guidance Overview....65
D.1.1 Introduction....65
D.1.2 FTP_PRO.1/BT Guidance....65
D.1.3 FTP_PRO.1/WLAN Guidance....65

Annex E (informative): Alignment with the Essential Requirements in CRA 66

History....72

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)) may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the ETSI IPR online database.

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

BLUETOOTH® is a trademark registered and owned by Bluetooth SIG, Inc.

Foreword

This Technical Specification (TS) has been produced by ETSI Technical Committee Cyber Security (CYBER).

The present document is part 1 of a multi-part deliverable covering the Consumer Mobile Device, as identified below:

Part 1: "Base Protection Profile";

Part 2: "Biometric Authentication Protection Profile Module";

Part 3: "Multi-user Protection Profile Module";

Part 4: "Consumer Module Devices - Preloaded Apps PP-Module";

Part 5: "Bootloader & Root of Trust Protection Profile Module".

Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the ETSI Drafting Rules (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

Introduction

Consumer mobile devices like smartphones are becoming the entrance to digital services, such as mobile banking, electronic identity verification, digital key management, etc. Meanwhile more and more security attack vectors are being explored, such as malicious applications, network eavesdropping. Defining security and assurance requirements for mobile devices can mitigate potential risks and drive the mobile device security to an appropriate level in order to protect users of such mobile devices. Smartphones and tablets are typical consumer mobile devices.

The present document identifies key assets to be protected in typical consumer usage scenarios and identifies security threats associated to these key assets. The identified threats are mitigated by security objectives, which are in their turn fulfilled by implementing appropriate security functional requirements.

The present document is defined as a Protection Profile (hereafter called PP) following PP structure from the Common Criteria (CC) standards [19], [20], [21], [22], [23] and [24] and therefore can be used for third party CC security assessments and certification.

The requirements in the present document take published standards, recommendations and guidance in clause 2 into consideration.

1 Scope

The present document defines a PP for Consumer Mobile Device (CMD), which is typically a user-customizable device utilizing an operating system, supporting installation and maintenance of applications, with wireless internet connectivity, high computation power and rich user interface, such as smartphones or tablets, used for various purposes by the individual owner.

The present document identifies key assets of the CMD to be protected and identifies the threats associated to them and the functional capabilities (objectives and security functional requirements) that are required to mitigate those threats. Finally, the present document specifies the security assurance requirements against which the CMD security can be assessed in a CC security evaluation.

The present document is intended for CMD manufacturers implementing those security requirements for device certification and for third parties looking to assess the security functions on CMD such as evaluators.

The Target Of Evaluation (TOE) described by the present document is a consumer mobile device. The following items are excluded from the scope:

- all applications (apps) downloaded by a user or preinstalled by the TOE manufacturer;
- all peripheral devices, including any data residing on these devices and any services associated with these devices, for example memory card;
- CMD features related to cellular mobile communication, including secure element which stores user credentials for cellular mobile communication, for example UICC [i.5].

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the ETSI docbox.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

[1] Void.

[2] Void.

[3] Void.

[4] Void.

[5] Void.

[6] IETF RFC 5246: "The Transport Layer Security (TLS) Protocol Version 1.2".

[7] IETF RFC 5280: "Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile".

[8] Void.

[9] Void.

[10] IETF RFC 8446: "The Transport Layer Security (TLS) Protocol Version 1.3".

[11] Void.

[12] Void.

[13] Void.

[14] Void.

[15] Bluetooth® SIG: "Bluetooth Core Specification, v5.2".

[16] Void.

[17] ISO/IEC 18033-1:2021: "Information security - Encryption algorithms - Part 1: General".

[18] Void.

[19] CCMB-2022-11-001 CC:2022 Revision 1, November 2022: "Common Criteria for Information Technology Security Evaluation, Part 1: Introduction and General Model".

[20] CCMB-2022-11-002 CC:2022 Revision 1, November 2022: "Common Criteria for Information Technology Security Evaluation, Part 2: Security Functional Components".

[21] CCMB-2022-11-003 CC:2022 Revision 1, November 2022: "Common Criteria for Information Technology Security Evaluation, Part 3: Security Assurance Components".

[22] CCMB-2022-11-004 CC:2022 Revision 1, November 2022: "Common Criteria for Information Technology Security Evaluation, Part 4: Framework for the specification of evaluation methods and activities".

[23] CCMB-2022-11-005 CC:2022 Revision 1, November 2022: "Common Criteria for Information Technology Security Evaluation, Part 5: Pre-defined packages of security requirements'.

[24] CCMB-2022-11-006 CC:2022 Revision 1, November 2022: "Common Methodology for Information Technology Security Evaluation".

[25] CCMB-2025-001 Version 1.2, October 15, 2025: "Errata and Interpretation for CC:2022 (Release 1) and CEM:2022 (Release 1)".

[26] Bluetooth® SIG: "Bluetooth Core Specification, v5.3".

[27] Bluetooth® SIG: "Bluetooth Core Specification, v5.4".

[28] Bluetooth® SIG: "Bluetooth Core Specification, v6.0".

[29] Bluetooth® SIG: "Bluetooth Core Specification, v6.1".

[30] Bluetooth® SIG: "Bluetooth Core Specification, v6.2".

[31] Bluetooth® SIG: "Bluetooth Core Specification, v6.3".

[32] IEEE 802.11-2020™: "IEEE Standard for Information Technology--Telecommunications and Information Exchange between Systems Local and Metropolitan Area Networks--Specific Requirements Part 11: Wireless LAN Medium Access Control (MAC) and Physical Layer (PHY) Specifications".

[33] IEEE 802.11-2024™: "IEEE Standard for Information Technology--Telecommunications and Information Exchange between Systems Local and Metropolitan Area Networks--Specific Requirements Part 11: Wireless LAN Medium Access Control (MAC) and Physical Layer (PHY) Specifications".

[34] IETF RFC 9110: "STD 97: HTTP Semantics".

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding, but are not required for conformance to the present document.

[i.1] ETSI EN 303 645 (V3.1.3): "CYBER; Cyber Security for Consumer Internet of Things: Baseline Requirements".

[i.2] Void.

[i.3] ISO/IEC TS 30104:2015: "Information Technology - Security Techniques - Physical Security Attacks, Mitigation Techniques and Security Requirements".

[i.4] Void.

[i.5] ETSI TS 102 221: "Smart Cards; UICC-Terminal interface; Physical and logical characteristics (Release 19)".

[i.6] GSMA SGP.22: "RSP Technical Specification".

[i.7] ETSI TS 133 102: "Digital cellular telecommunications system (Phase 2+) (GSM); Universal Mobile Telecommunications System (UMTS); LTE; 5G; 3G security; Security architecture (3GPP TS 33.102)".

[i.8] ETSI TS 133 401: "Digital cellular telecommunications system (Phase 2+) (GSM); Universal Mobile Telecommunications System (UMTS); LTE; 3GPP System Architecture Evolution (SAE); Security architecture (3GPP TS 33.401)".

[i.9] ETSI TS 133 501: "5G; Security architecture and procedures for 5G System (3GPP TS 33.501)".

[i.10] BSI-CC-PP-0084-V2-2026: "Security IC Platform Protection Profile including Functional Packages" version 2.0, February 2026.

[i.11] GSMA SGP.25: "Embedded UICC for Consumer Devices Protection Profile".

[i.12] GSMA SGP.08: "Security Evaluation of Integrated eUICC".

[i.13] GSMA SGP.24: "GSMA SGP.24: "RSP Compliance Process".

[i.14] Void.

[i.15] "ECCG Agreed Cryptographic Mechanisms" version 2, 6 May 2025.

[i.16] ETSI TS 103 732-2 (V2.1.1): "Cyber Security (CYBER); Consumer Mobile Device; Part 2: Biometric Authentication Protection Profile Module".

[i.17] ETSI TS 103 732-4 (V2.1.1): "Cyber Security (CYBER); Consumer Mobile Device; Part 4: Preloaded Applications Protection Profile Module".

[i.18] ETSI TS 103 732-5 (V2.1.1): "Cyber Security (CYBER); Consumer Mobile Device; Part 5: Bootloader & Root of Trust Protection Profile Module".

[i.19] Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

3 Definition of terms, symbols and abbreviations

3.1 Terms

For the purposes of the present document, the following terms apply:

accessibility services: specialized, system-level features designed to assist users with disabilities

ad network: technology platform used to match the sale of ads to be displayed to users between publishers and advertisers

atomic update: update process in which the result will either be a completely successful update or the update process will be completely abandoned or reversed, returning to the state before the update process was started

authentication factor: general term that can stand for any input used to verify a user as an authentication credentialThere are three types of possible factors:

- **biometric authentication factor:** use of a biometric sample matched to template generated by an enrolment process (and possibly updated during successful authentication attempts);
- **external authentication factor:** use of a separate item in possession of the user to provide authentication such as a security key;
- **known authentication factor:** use of something the user knows, a password, PIN or pattern for authentication.

best practice cryptography: cryptography that is suitable for the corresponding use case and has no indications of a feasible attack with current readily available techniques

consumer mobile device: user customizable device utilizing an operating system, supporting installation and maintenance of applications, with wireless internet connectivity, high computation power and rich user interface, used for various purposes by the individual owner

critical security parameters: parameters, such as stored user credentials (or keys used to encrypt them), keys used to encrypt assets, securely boot the device, or authenticate updates which need to be stored securely

derivation: cryptographic method for deriving keys from input values such as passwords that increase the computational cost of guessing the input values (such as in a brute force attack)

device ID: unique identity of a consumer mobile device, which is not resettable

EXAMPLE: Typical examples of a device ID are the IMEI and SN of a device.

device unique key: unique key stored in the device hardware during the initial manufacturing of the device, which is used to derive or encrypt other keys

downloaded application: application installed by the choice of the user through an ADP

embedded UICC: UICC which is not easily accessible or replaceable, is not intended to be removed or replaced in the terminal, and enables the secure changing of subscriptions

initial CMD setup: setup process that occurs when the device is either powered on by the consumer for the first time or after a factory reset and configures the device for first use, not including recovery or restore processes that may be invoked by the user

keystore: secure protected container for cryptographic keys and digital certificates

lock screen: screen that is displayed when the device is locked and requires credentials to be entered to access the primary functionality of the TOE

lock screen (boot): screen that is displayed when the device is locked after the device has been (re)started, prior to any user successfully entering any credentials

main OS: primary operating system of the device (as opposed to subsystems that may provide specialized, usually security-related, functions)

operational data: data generated by the TOE as part of normal use

preinstalled application: application provided by the TOE manufacturer installed without user intervention either prior to or during the initial CMD setup process

NOTE: Preinstalled applications are a type of downloaded applications and can be uninstalled by the user.

preloaded application: application provided by the TOE manufacturer as part of the system software that cannot be uninstalled by the user

security assurance requirements: description of how assurance is to be gained that the TOE meets the SFRs

security functional requirement: requirement, stated in a standardized language, which is meant to contribute to achieving the security objectives for a TOE

NOTE: As defined in [19].

security objective: statement of an intent to counter identified threats and/or satisfy identified organization security policies and/or assumptions

NOTE: As defined in [19].

security problem: statement, which in a formal manner defines the nature and scope of the security that the TOE is intended to address

NOTE: As defined in [19].

separate execution environment: operating environment separate from the main OS with highly restricted access used to provide secure isolation for sensitive operations

(internal) storage: storage which is not intended to be removed from the device (generally this would be integrated into the main board of the device)

(removable) storage: storage which is intended by design to be added to and removed from the device over an available connector (such as a microSD slot or an external port that can be used to mount media)

system permission: permission granted by the main OS to manage itself (such as power off), provide core functions (such as SMS and Telephone), or access to underlying software and hardware interfaces

system software: main OS, bootloaders, any preloaded apps and other components necessary for the device to function as expected

system software update: update for the system software, including firmware updates for any updateable component on the device itself (but does not update user data assets or downloaded apps)

target of evaluation: set of software, firmware and/or hardware possibly accompanied by guidance

NOTE: As defined in [19].

TOE security functionality: combined functionality of all hardware, software, and firmware of a TOE that are relied upon for the correct enforcement of the security functional requirements

trusted peer device: device with a trusted relationship with the TOE for purposes of interaction with the TOE

EXAMPLE: Screen sharing, file sharing, moving the entire content from an old device to a new device.

trustworthy update source: central repository from which updates to the system software can be downloaded, typically managed by the TOE manufacturer or the network carrier

UICC: *smart card* that conforms to the specifications written and maintained by the ETSI Secure Element Technologies Technical Body

NOTE: UICC is neither an abbreviation nor an acronym.

user: "human user" of the TOE, someone in physical presence of the TOE, as opposed to another system or service for which actions may be taken

user data assets: data owned by or related to the user

version ID: identifier used to determine the difference between two releases of software

3.2 Symbols

Void.

3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

3GPP	3G (mobile) Partnership Project
ADP	Application Distribution Platform
AES	Advanced Encryption Standard
API	Application Program Interface
App	Application
BAF	Biometric Authentication Factor
CC	Common Criteria
CEM	Common Evaluation Methodology
CMD	Consumer Mobile Device
DEK	Data Encryption Key
DUK	Device Unique Key
EAF	External Authentication Factor
EAL	Evaluation Assurance Level
ECD	Extended Component Definition
ECDH	Elliptic Curve Diffie-Hellman
ECDSA	Elliptic Curve Digital Signature Algorithm
EEPROM	Electrically Erasable Programmable Read Only Memory
eSE	embedded Secure Element
eUICC	embedded UICC
FCS	Functional class Cryptographic Support
FDP	Functional class User Data Protection
FIA	Functional class Identification and Authentication
FMT	Functional class Security Management
FPR	Functional class Privacy
FPT	Functional class Protection of the TSF
FTP	Functional class Trusted Path/Channels
GCF	Global Certification Forum
GSM	Global System for Mobile
HMAC	Hash-based Message Authentication Code
ID	Identifier
IMEI	International Mobile Equipment Identity
IoT	Internet of Things
IPC	Inter-Process Communication
ISO/IEC	International Organization for Standardization/International Electrotechnical Commission
IT	Information Technology
JTAG	Joint Test Action Group
KAF	Known Authentication Factor
KDF	Key Derivation Function
KEK	Key Encryption Key
MAC	Message Authentication Code
NFC	Near Field Communication
NIST	National Institute of Standards and Technology
OEM	Original Equipment Manufacturer
OS	Operating System
PBKDF	Password-Based Key Derivation Function

PCS	Personal Communication Service
PIN	Personal Identification Number
PP	Protection Profile
RSA	Rivest-Shamir-Adleman (algorithm)
QR	Quick Response
RNG	Random Number Generator
SAR	Security Assurance Requirement
SEE	Separate Execution Environment
SFP	Security Function Policy
SFR	Security Functional Requirement
SHA2	Secure Hash Algorithm 2
SHA3	Secure Hash Algorithm 3
SMS	Short Message Service
SN	Serial Number
SoC	System on Chip
SPD	Security Problem Definition
SPU	System Processing Unit
ST	Security Target
TLS	Transport Layer Security
TOE	Target Of Evaluation
TSF	TOE Security Functionality
UI	User Interface
USB	Universal Serial Bus
WLAN	Wireless Local Access Network

4 TOE Definition

4.1 TOE Overview

The TOE described by the present document is a subset of a CMD as shown in figure 1. The CMD includes hardware, an operating system and apps. Apps are categorized as preloaded, preinstalled and downloaded apps. Examples of a CMD include smart phone, tablet and other device with similar capabilities. Users can customize their CMDs (modify their UI appearance, download apps, etc.) and use these devices for a wide range of purposes.

The TOE includes hardware, the Operating System (main OS) and preloaded apps that are delivered with the CMD out of the box. Preinstalled and downloaded apps that can be completely uninstalled by the user are not considered part of the TOE.

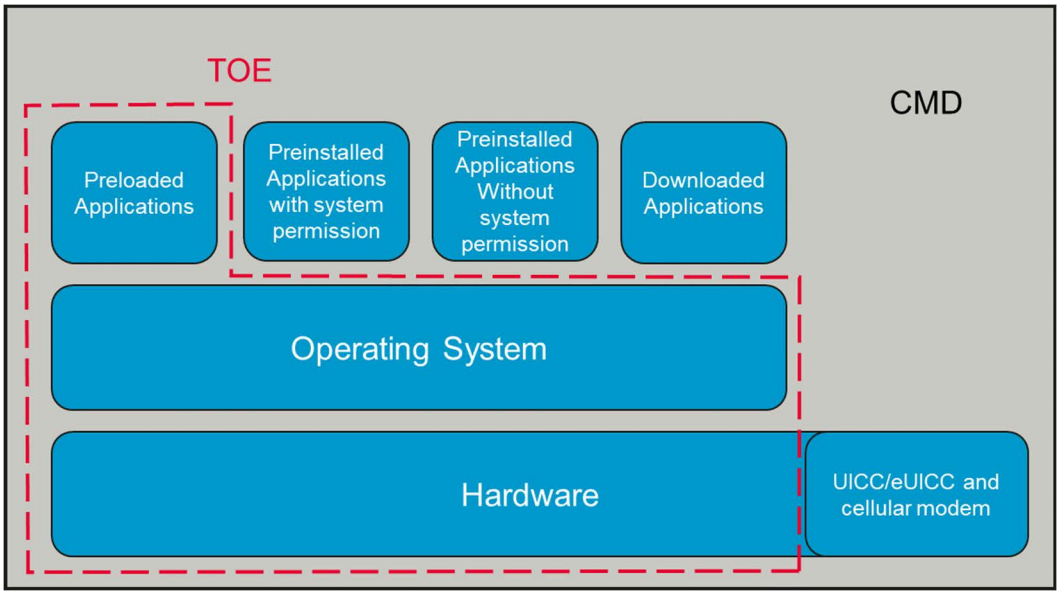


Figure 1: TOE boundary

The hardware of the TOE includes the hardware platform, physical enclosure and peripheral components such as sensors and the display. The hardware does not include any devices removable by a user, including any data residing on these devices and any services associated with these devices, for example a memory card. Any data on these devices or services associated with these devices is out of scope of the TOE.

The security functionality and radio interface of the TOE related to cellular mobile communication are defined in [i.7], [i.8], [i.9] and will be certified by Global Certification Forum (GCF) and PCS Type Certification Review Board (PTCRB) or any other cybersecurity compliance standards.

Security of a secure element which stores user credentials for cellular mobile communication, e.g. UICC, eUICC [i.6], and integrated eUICC is specified in [i.10], [i.11], [i.12] and [i.13], and will be certified by a CC Certification Body.

Therefore, these cellular mobile communication functions are out of scope for the present document. It is assumed that the TOE meets applicable security requirements defined in these specifications and TOE manufacturer should provide evidence for such assumption if the evaluation of the TOE depends on such evidence, such as certificate of eUICC.

The main OS of the TOE controls and manages the hardware and the apps (downloaded, preinstalled and preloaded) and provides the user interface and application programming interface(s).

Apps on the CMD can be categorized in many ways, but generally are divided into downloaded, preinstalled and preloaded. The difference between them is whether they are present on the device when it is delivered to the consumer (some preinstalled apps and all preloaded apps). For the purposes of the TOE, preloaded apps are in scope.

Downloaded apps are those installed by the user by the choice of the user. Generally this is done through an App Distribution Platform (ADP) (this is out of scope of the TOE), though the exact mechanism for the installation of an app is up to the user. TOE manufacturers normally provide an ADP on the device for the user to take advantage of. The ADP generally also provides the ability to update the apps on the device that have been installed from the ADP. In some cases, to preserve user bandwidth, the TOE manufacturer may provide downloaded apps to the user as part of the initial system configuration. Any apps, regardless of whether they are pre-installed or downloaded by the user, that can be removed completely by the user, are treated as downloaded apps.

Preinstalled apps are those that are installed by the TOE manufacturer. These preinstalled apps may be provided as part of the device such that they are installed even when offline during the initial CMD setup, or they may be downloaded from a trustworthy ADP. Preinstalled apps, including those provided with the device, can be uninstalled by the user like downloaded apps, and are updated through the trustworthy ADP. Preinstalled apps are divided into categories by the permissions assigned to them by the TOE manufacturer. Preinstalled apps are not in scope of the TOE.

Preloaded apps are provided by the TOE manufacturer as part of the system software. Depending on the preloaded app, updates may be applied as part of the system software update or in the same manner as a downloaded app. As part of system software updates the TOE manufacturer may change the preloaded apps included on the device (adding or removing the apps from the system software).

Permissions are used to control access to specific services or capabilities on the device. A TOE manufacturer may provide specialized access to preloaded apps (such as an app for phone calls or for downloading system software updates). These permissions are collectively called system permissions, and can only be assigned by the TOE manufacturer to preloaded or preinstalled apps, they cannot be assigned to downloaded apps. A user can control access to other capabilities provided by the device, such as to storage or location services. Preloaded or preinstalled apps may also request permissions for additional capabilities (ones controlled specifically by the user), either on first use, or have them assigned by the TOE manufacturer by default. Use of permissions ensures that apps do not have access to more capabilities than are necessary.

The present document is intended to be used with a TOE which has system software approved by the TOE manufacturer, not an altered system which may enable the user to manage restricted system permissions, such as a rooted device.

The TOE manufacturer shall define the TOE clearly as part of submission for CC evaluation.

4.2 Usage and Major Security Features

The TOE is a subset of a CMD with wireless connectivity, high computation power and rich user interface. A user can customize the device by downloading apps and changing settings. A user can perform a wide range of actions with the TOE, such as make phone and video calls, perform various productivity tasks, play games, music and videos, and access the Internet.

The TOE interacts with its environment as shown in figure 2. The local environment consists of the device itself and peer devices such as those connected over short-range connections (such a wired connection, Bluetooth® or NFC). The remote environment consists of systems connected over longer-range wireless protocols such as WLAN (Wi-Fi®) and Mobile Networks (cellular). The connectivity provided by the Mobile Network is optional for this evaluation based on the capabilities of the CMD, though the connection offered by the network may be used by the TOE to access remote services for supported devices. These have been highlighted in a different colour in the figure to show this difference.

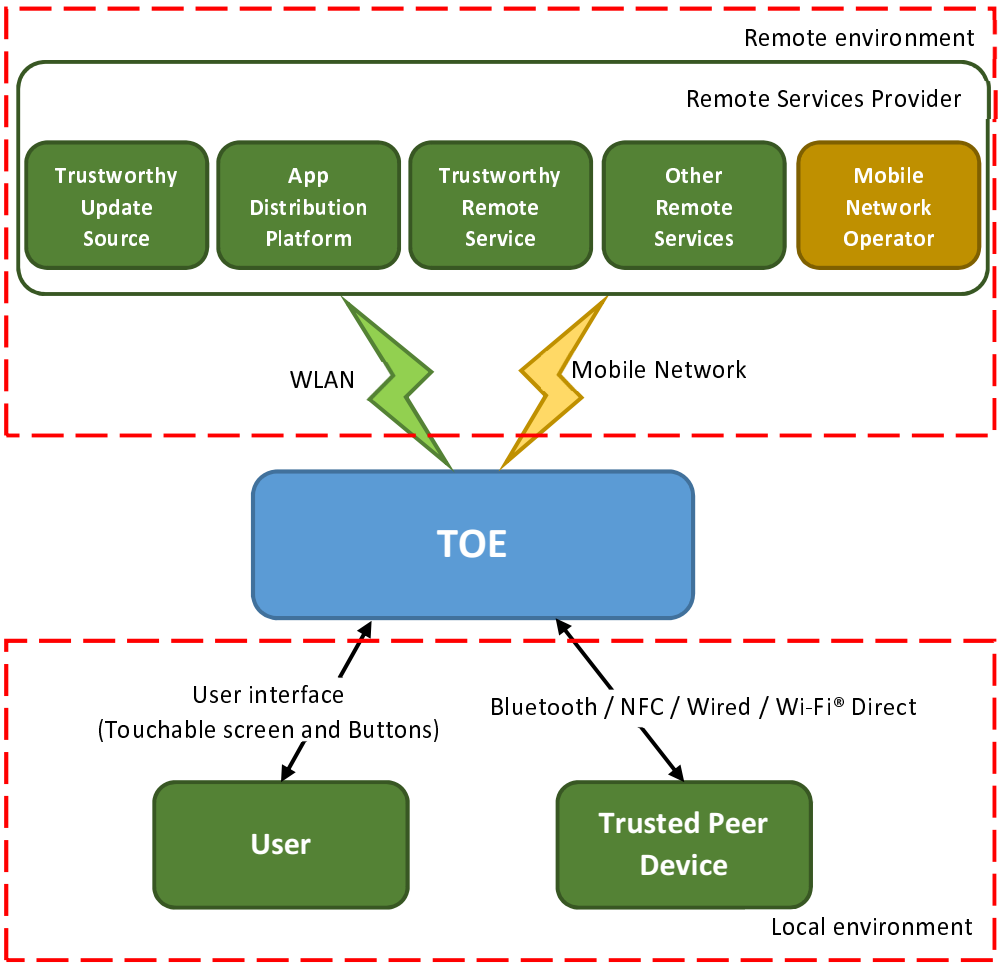


Figure 2: TOE environment

The TOE has a local environment with:

- A user, who physically interacts with the TOE across the provided interface(s).
- One or more Trusted Peer Devices, which can interact with the TOE in actions such as screen sharing or collaborative editing.

The TOE has a remote environment with:

- A Trustworthy Update Source, from which the TOE can download system software updates for the TOE software. The update source assured to be secure and the authenticity and integrity of the updates are ensured by the TOE manufacturer. These updates are digitally signed, and the TOE checks whether this signature is correct.
- The App Distribution Platform (ADP) of the TOE manufacturer and/or OS developer, from which the TOE can download and install apps (the TOE manufacturer may provide multiple ADPs in the TOE boundary). The App Distribution Platform performs operations for the detection of malicious in-app behaviour, conduct privacy disclosure inspections for apps that call, collect or upload sensitive data from users without permission, as well as scan apps for the presence of loopholes, vulnerabilities or backdoors.

How the ADP performs security checks of applications is out of scope of this evaluation. The ADP application included on the TOE is in scope.

To be considered a trustworthy source, the App Distribution Platform does best practice security checking taking into account of state of art, but it is not assumed App Distribution Platform is free of malicious apps.

- (Out of scope) A user may install additional ADP applications, in which case the user takes the responsibility for the security of apps downloaded and installed from any additional ADPs.

- (Optionally) Trustworthy Remote Services provided by the TOE manufacturer. A user can use remote services to access user data assets in the TOE. It is assumed that the remote service will be secure, and vulnerabilities of remote service are not in scope of present document. The TOE manufacturer should ensure the security of the connection from the TOE to any remote service by utilizing capabilities provided by the TOE for secure remote connections.

- Other Remote Services offered by third parties, such as enterprise services, additional ADPs used by the user, websites, gaming servers, etc. The present document provides no assurance in these remote services, so it is up to the user to trust a particular remote service. The security of the connection from the TOE to any remote service can be secured utilizing capabilities provided by the TOE for secure remote connections but it is up to the App Developer to utilize those capabilities.

- (Optional) one or more Mobile Network Operators when the TOE supports cellular radio connection. It is assumed that the Mobile Network Operators will provide secure cellular communication with the TOE.

The TOE supports the following classification of user data assets:

- Low: This data is to be encrypted in such a way that the data can only be decrypted on the TOE itself, when the TOE is successfully powered on, low data is decrypted and can be accessed without user authentication, e.g. alarm.

- Medium: This data is to be encrypted in such a way that the data can only be decrypted on the TOE and when the user is logged in after first successfully authentication, e.g. calendar.

- High: This data is to be encrypted the same as Medium, but additionally it can only be accessed when the screen of the TOE is unlocked, e.g. sensitive health data.

It is important to be clear that the TOE shall provide three classification levels, but only Medium is explicitly implemented by the TOE itself for user data assets. Low and High classifications are generally implemented as an additional set of APIs as part of the main OS that an app can use to enable specific data storage functionality. As such, while the TOE supports the three classifications, only Medium is provided by default on the TOE for user data assets while Low/High requires apps to be provided (either by preload, preinstall or download) to store user data assets according to one of those classifications. The key hierarchies described by these classification levels do not need to be tied together. Normally Medium and High will share a key hierarchy while Low will have a separate key hierarchy, but it is possible to have multiple independent hierarchies for different purposes.

Each of these classes of user data assets is encrypted (see FCS_CKH_EXT.1) by a Data Encrypting Key (DEK). These DEKs, in turn, can be encrypted themselves by Key Encryption Keys (KEKs), which can be encrypted with or derived from further KEKs, etc.

Each DEK or KEK can be randomly generated, or it can be derived from other keys (such as the DUK) or data (such as the user password), or a combination of random generation and derivation. The whole structure of data and keys used to derive/encrypt a DEK is called a key hierarchy, which typically starts from the DUK and/or user credentials and have derivation/encryption of KEKs in the middle of the hierarchy (see the FCS_CKH_EXT.1 requirements).

DUK is a unique key stored in the device hardware during the initial manufacturing of the device, which is accessible only by a hardware cryptography module and not directly exposed to any device software.

To prevent attackers from decrypting the user data assets all keys and data used for derivation in the hierarchy are to be protected, by being encrypted with a KEK, or by being discarded after use and re-generated/re-derived when needed, or by being securely stored (see FPT_PHP.3).

When a user wishes to dispose of the TOE and permanently delete all user data assets, this can be done by deleting one or more of the appropriate keys from the key hierarchy, thereby ensuring that the data can no longer be decrypted as either the key needed for decryption has been deleted or it is not possible to decrypt that key (see FCS_CKM.6), or all user data assets can be erased.

The major security features are:

- Application Lifecycle: the update process for each preloaded application is defined to ensure it is maintained. When a preloaded application is uninstalled (which may leave an older version of the software available), the TOE provides information to the user about the implications of the removal.
- Authentication of user: to ensure that the user is authenticated by the TOE before he/she can fully use the TOE (it may be possible to make very limited use of the TOE before authentication, such as making emergence call).
- Authentication of Trusted Peer Devices: the TOE can allow other devices to act as a trusted peer device for purposes such as screen sharing and collaborative editing. To be able to do this, these devices first authenticate themselves.
- Permission management of apps: to ensure that apps can only access to user data assets on the TOE and services provided by the TOE which are essential to their operation and where permission has been granted by the user and/or by the TOE manufacturer.
- Protection against physical attacks: the TOE can protect keys, data used to derived keys and other sensitive data from being read or modified by physical attacks.
- Protection against tracking by App Developers and advertisers: The TOE can provide an alias to App Developers and advertisers, so that they have limited tracking of the user. The user can replace that alias with another alias to limit this tracking.
- Secure communication: the TOE offers one or more secure communication channels, protected against unauthorized modification and unauthorized disclosure. These channels can subsequently be used by apps and by the TOE itself for various communication purposes.
- Secure updating of apps: the TOE can update apps (as determined by the type of app) by downloading an update from the ADP.
- Secure updating of system software: the TOE can update the system software by downloading a system software update from a Trustworthy Update Source to address known vulnerabilities in a timely manner. System software updates do not update user data assets or any downloaded apps (and data associated with downloaded apps).
- Self-protection and integrity verification of the TOE: the TOE protects both itself and other apps against malicious apps who can try to hack into the TOE. The TOE also checks its own integrity every time it starts up to check whether it has been altered.

4.3 Additional Hardware/Software/Firmware required by the TOE

The TOE is standalone and does not require any additional software/firmware, but trusted peer device(s) may be required.

4.4 Base-PP reference

Base-PP Title	ETSI TS 103 732-1: "Consumer Mobile Device; Part 1: Base Protection Profile"
Base-PP Version	3.1.1
Base-PP Date	September 16, 2026

4.5 Conformance Claim

The present document:

- claims conformance to CC:2022 Revision 1 [19], [20], [21], [22], [23], [24] and the CC and CEM errata an interpretation [25];

- is CC Part 2 [20] extended and CC Part 3 [21] extended;
- does not claim conformance to any other PP;
- conforms to the package EAL2 augmented with ALC_CMS.3, ADV_PDM_EXT.1 ALC_DVS_EXT.0 & ALC_FLR.3.

In order to be conformant to this PP, a TOE shall demonstrate Exact Conformance. Exact Conformance, as a subset of Strict Conformance as defined by the CC, is defined as the Security Target (ST) containing all of the Security Functional Requirements in clause 8.3 (these are the mandatory SFRs) of this PP. While iteration is allowed, no additional requirements (from the CC parts 2 or 3, or definitions of extended components not already included in this PP) are allowed to be included in the ST. Further, no SFRs in clause 8.3 of this PP are allowed to be omitted.

While for SFRs the use of mandatory, optional and selection-based SFRs allows some customization when modelling the TOE, this does not work for the SPD in clause 5 and the security objectives in clause 6. Some parts in these chapters are marked as "(applies to ... only)" (e.g. "(applies to distributed TOEs only)"). These parts only need to be included in the ST for TOEs that comply with the corresponding conditions (i.e. parts marked as "(applies to distributed TOEs only)" only need to be included in STs for distributed TOEs and shall be omitted otherwise).

The PP-Modules that are allowed to specify this Protection Profile as a Base-PP are specified in the Approved Components list at:

- https://www.etsi.org/technologies/consumer-mobile-device-protection-profile.

5 Security Problem Definition

5.1 Assets and interfaces of the TOE

Assets to be protected:

- User data assets stored in the TOE and in transit to the Trustworthy Remote Service, such as:
  - user files: photos, videos, etc.;
  - user location: location information, location record, etc.;
  - non-TOE account information;
  - user communication: communication records, address books, emails, SMS, chat session, audio/video calls, etc.;
  - credentials for other devices and/or services, e.g. login password for web service;
  - data collected by sensors: acceleration sensor, blood sugar, body fat ratio, heart rate, blood pressure, etc.;
  - App data: list of installed apps, user data in apps, etc.
- TSF data: data which is used for the enforcement of operations of security functions, such as configuration data, user authentication data.
- The main OS and apps included in the TOE.

The interfaces defined here are used in the description of the threat agents and threats to the assets protected by the TOE. These interfaces implement security protocols to protect some of the TOE assets when transit to and from the TSF.

Interfaces of the TOE:

- The radio interface(s): these are wireless interfaces to wireless networks such as those defined by Wi-Fi® or Bluetooth®.

- The network interface(s): these are interfaces to networks such as the internet. These interfaces generally (though not exclusively) lie on top of radio interfaces such as those provided by 3GPP (not included within the scope of the TOE), Wi-Fi® or Bluetooth®.
- The physical interface: this is the physical enclosure of the TOE and may include the following types of ports: JTAG, USB, Lightning®, charging, media, etc.
- The user interface: this interface includes the screen, buttons, speaker, etc.
- The application interface: this is the API that applications can use to interact with the underlying operating system.

5.2 Threat agents and threats

The following threat Agents are defined for the TOE (note that one entity may be multiple threat agents simultaneously):

- TA.FLAWAPP: a malicious or poorly programmed app that the user has installed on the TOE and that therefore has access to the application interface, and possibly to the local wireless interface and/or the wide-area network interface.
- TA.LOCAL: a threat agent in the general vicinity of a TOE when it is used, and therefore has access to the local wireless interface.
- TA.PHYSICAL: a threat agent who has physical access to the TOE, and therefore to both the user interface and the physical interface.
- TA.REMOTE: a threat agent with access to the wide-area interface.

Threat Agents are limited to Basic attack potential as defined by EAL2. For further detail and examples on attack potential, see annexes B.3, B.4 and B.5 of [6].

The present document identifies threats based on each interface defined in clause 5.1 on what nefarious actions each of the threat agents could perform on that interface. Similar threats are subsequently combined into one threat where possible. The threats are identified as below.

Attacks based on the user revealing their credentials, such as voluntarily disclosing the password to an attacker, writing down a PIN where an attacker can see it, or an attacker replacing the TOE with a similar device where the user enters their credentials on, after which the attacker uses these credentials to login on the real TOE, are out-of-scope of the present document.

T.APP_REVERSION - TA.LOCAL or TA.REMOTE attempts to access user data assets utilizing a TA.FLAWPREAPP that has been reverted to an earlier version with known flaws.

T.COUNTERFEIT_DEVICE - TA.PHYSICAL or TA.LOCAL attempts to connect to the TOE and thereby gain access to user data assets with a device masquerading as a trusted peer device.

T.EAVESDROP - TA.LOCAL, TA.REMOTE or TA.FLAWAPP read communication between the TOE and other entities and thereby access confidential user data assets in transit.

T.FLAWAPP_ACCESS - TA.FLAWAPP attempts to access to user data assets that it should not be able to access and subsequently modify them or export them to third parties. This includes additional data gathered from the TOE sensors (location, camera, microphone, etc.).

T.FLAWAPP_HACKS_OTHER_APPS - TA.FLAWAPP attempts to modify the behaviour of other apps, without access permission to the peer app being granted through the operating system or the peer app.

T.FLAWAPP_HACKS_TOE - TA.FLAWAPP attempts to modify the security behaviour of the TOE main OS.

T.IMPERSONATE - TA.PHYSICAL impersonates the legitimate user of the TOE thereby gaining access to the user data assets.

T.MODIFY_COMMS - TA.LOCAL or TA.REMOTE initiate or intercept communication between the TOE and other entities and thereby modify user data assets in transit.

T.MODIFY_DEVICE - TA.PHYSICAL obtains a TOE, modifies that TOE, and reinserts that TOE into the supply chain. Later on a legitimate user buys this CMD and the modified CMD allows compromise of the user data assets.

T.NEW_ATTACKS - Any of the threat agents can make use of newly discovered vulnerabilities in the TOE main OS or apps and thereby becomes able to execute one or more of the other threats and threatening all the assets.

T.PHYSICAL - TA.PHYSICAL attempts to gain access to all the assets by accessing physical interfaces of the TOE while in possession of the device.

T.RECOVER_DATA - A user sells their TOE and attempts to remove all user data assets beforehand, but the new user (TA.PHYSICAL) is still able to retrieve some or all of these user data assets.

T.SPOOF - TA.LOCAL or TA.REMOTE create a spoofed device or service and wait for the TOE to connect to that device or service. Once the TOE connects to the spoofed device or service the threat agents actively or passively extract user data assets from the TOE.

5.3 Organizational Security Policies

P.DATA_CLASSIFICATION - The TOE manufacturer classifies groups of user data assets into at least three different classes, according to policies such as the potential harm that may result to the user if the user data asset were inappropriately accessed, used, or disclosed:

- Low: user data assets to which unauthorized access is expected to have limited adverse effect on the user. Low user data assets can only be decrypted on the TOE.
- Medium: user data assets to which unauthorized access can have serious adverse effect on the user. Medium user data assets can only be decrypted on the TOE following the first successfully user authentication.
- High: user data assets to which unauthorized access can have severe adverse effect on the user. High user data assets can only be decrypted on the unlocked TOE following a successful user authentication.

5.4 Assumptions

A.APP_DISTRIBUTION_PLATFORM - It is assumed that the user will only install apps which have been downloaded from the App Distribution Platform of the TOE manufacturer and/or OS developer, which has performed best practice security checks on these apps. Security checks include but are not limited to:

- detect malicious in-app behaviour;
- conduct privacy disclosure inspections for apps that call, collect or upload sensitive data from user without permission;
- scan apps for the presence of loopholes, vulnerabilities or backdoors;
- verify an App Developer has a valid developer certificate.

A.CELLULAR_MOBILE_COMMUNICATION - It is assumed that the modem providing the cellular mobile communication complies with the ETSI specifications defining the cellular mobile communication radio interfaces and the related security architectures ([i.7], [i.8] and [i.9]).

A.MINIMIZE_APP_DATA - Minimization of application-specific user data assets is enforced by the application that is using the data.

PASSWORD_PIN_PATTERN - It is assumed that the user will not downgrade/disable authentication to the TOE or choose easily guessable known authentication factors.

A.TRUSTWORTHY_REMOTE_SERVICE - It is assumed that the remote service provided by the TOE manufacturer is secure and unauthorized parties cannot access to the user data assets or operational data on the TOE via remote services.

A.TRUSTWORTHY_UPDATE_SOURCE - It is assumed that the TOE will trust the Trustworthy Update Source to install secure updates delivered by the update source.

6 Security Objectives

6.1 Security Objectives for the TOE

O.ACCESS_CONTROL - The TOE ensures that apps only gain access to user data assets that they are specifically allowed by the user or the main OS to have access to.

O.AUTHENTICATE_PEER_DEVICE - The TOE allows other devices to authenticate themselves to the TOE and become a trusted peer device.

O.AUTHENTICATE_USER - The TOE will identify and authenticate the user of the TOE before allowing that user has full access to the TOE functionality.

O.AUTHENTICATED_UPDATES - The TOE only allows updates of its operating system and apps when these updates are authenticated as being from a trustworthy source.

O.CRITICAL_STORAGE - The TOE provides storage to ensure confidentiality and integrity for critical security parameters.

O.CRYPTOGRAPHY - The TOE provides best practice cryptographic functionality (encryption, decryption, signing, signature checking, key establishment), to implement other security objectives.

O.DATA_CLASSIFICATION - The TOE supports and encrypts at least three different classes of user data assets:

- Low: user data assets that can only be decrypted on the TOE.
- Medium: user data assets that can only be decrypted on the TOE following the first successfully user authentication.
- High: user data assets that can only be decrypted on the unlocked TOE following a successfully user authentication.

O.OLD_APP_WARNING - The TOE shall provide the user with notifications when uninstalling updates from a preloaded application contained in the system software when an older version of the preloaded application is used.

O.PROTECT_ASSETS_AT_REST - The TOE ensures the confidentiality of user data assets when not in use, e.g. by encryption.

O.PROTECT_COMMS - The TOE ensures confidentiality and integrity of assets are protected during transmission over secure protocol.

O.RANDOMS - The TOE provides best practice random number generation functionality to support O.CRYPTOGRAPHY.

O.SECURE_BOOT - The TOE, at the start of its boot process, checks the TSF to ensure it has not been tampered with.

O.SECURE_WIPE - The TOE is able to make user data assets permanently unreadable.

O.SELF_PROTECTION - The TOE protects itself against apps attempting to modify TSF data and its security behaviour.

O.SEPARATION - The TOE provides a separate security domain for each app, protecting them against unauthorized modification by other apps.

6.2 Security Objectives for the Operational Environment

OE.APP_DISTRIBUTION_PLATFORM - The operational environment ensures that the user of the TOE is instructed to use the App Distribution Platform of the TOE manufacturer or OS provider which performs security checks on these apps.

OE.CELLULAR_MOBILE_COMMUNICATION - The operational environment includes a modem providing the cellular mobile communication which complies with the ETSI specifications defining the cellular mobile communication radio interfaces and the related security architectures ([i.7], [i.8] and [i.9]). The security assurance for the modem secure functionalities may be provided by/through a Global Certification Forum or PCS Type Certification Review Board certification, or any other cybersecurity compliance standards.

OE.MINIMIZE_APP_DATA – Apps installed on the device will minimize the user data collected as part of their operations.

OE.PASSWORD_PIN_PATTERN - The operational environment ensures that user of the TOE is instructed not to disable or downgrade the authentication of the TOE or choose easily guessable known authentication factors such as aaaa, 1234, birthdates and the like.

OE.TRUSTWORTHY_REMOTE_SERVICE - The operational environment ensures the remote services are sufficiently protected from unauthorized access.

OE.TRUSTWORTHY_UPDATE_SOURCE - The operational environment ensures the security update delivered by the Trustworthy Update Source is sufficiently protected from tampering and is secure to be installed by the TOE.

6.3 Security Objectives Rationale

Threat	Rationale
T.APP_REVERSION	This threat is countered by O.OLD_APP_WARNING by ensuring the user is aware a preloaded application will be replaced by an older version if the preloaded application is part of the system software.
T.COUNTERFEIT_DEVICE	This threat is countered by O.AUTHENTICATE_PEER_DEVICE which forces devices to authenticate in order to become a trusted peer device.
T.EAVESDROP	This threat is countered by O.PROTECT_COMMS that enables protection of the communication channel(s) against disclosure. This threat is further countered by O.CRYPTOGRAPHY to encrypt these channels and O.RANDOMS to provide random numbers for key generation used in the encryption.
T.FLAWAPP_ACCESS	This threat is countered by O.ACCESS_CONTROL preventing the app from gaining access to user data assets which they do not have permission to access, so they cannot be modified or exported.
T.FLAWAPP_HACKS_OTHER_APPS	This threat is countered by O.SEPARATION, stating that the TOE provides a security domain for each app, thereby separating them from other apps, and O.AUTHENTICATED_UPDATES to prevent unauthorized updates of any part of the TOE.
T.FLAWAPP_HACKS_TOE	This threat is countered by O.SELF_PROTECTION and O.SECURE_BOOT, stating that the TOE protects itself against apps attempting to alter its security behaviour, and O.AUTHENTICATED_UPDATES to prevent unauthorized updates of any part of the TOE.
T.IMPERSONATE	This threat is countered by O.AUTHENTICATE_USER ensuring that only authenticated user can access the device functionality.
T.MODIFY_COMMS	This threat is countered by O.PROTECT_COMMS that enables protection of the communication channel(s) against disclosure. This threat is further countered by O.CRYPTOGRAPHY to encrypt these channels and O.RANDOMS to provide random numbers for key generation used in the encryption.
T.MODIFY_DEVICE	This threat is countered by O.SECURE_BOOT that can detect integrity issues with the TOE and O.CRITICAL_STORAGE that prevents attackers from modifying the keys from O.SECURE_BOOT, which would make it ineffective.
T.NEW_ATTACKS	This threat is countered by O.AUTHENTICATED_UPDATES, allowing the TOE to be updated to stay ahead of new attacks and/or discovered vulnerabilities.
T.PHYSICAL	This threat is countered by: • O.PROTECT_ASSETS_AT_REST ensuring that assets are encrypted (or erased) when not in use thus preventing a physical attacker who directly accesses TOE storage media from reading that data. • O.CRYPTOGRAPHY and O.RANDOMS ensures that stored data is encrypted with strong keys.

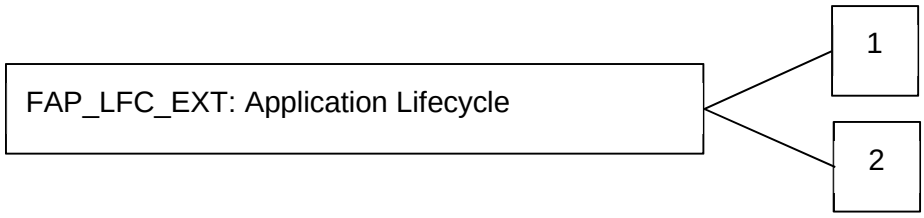
Threat	Rationale
	• O.CRITICAL_STORAGE to securely store the encryption/decryption keys. • O.SECURE_BOOT to ensure that the integrity of the TOE is checked every time it boots thus preventing undetected loss of integrity from physical attack. • O.ACCESS_CONTROL to ensure that access to physical interface such as charging interface is controlled by the user. • O.AUTHENTICATE_USER to ensure that authentication limits what is available on the device when the TOE is not in the user's possession.
T.RECOVER_DATA	This threat is countered by O.SECURE_WIPE, O.CRYPTOGRAPHY and O.RANDOMS, ensuring that the user data assets, which are all encrypted with strong keys, are permanently unreadable.
T.SPOOF	This threat is countered by O.AUTHENTICATE_USER and O.ACCESS_CONTROL that ensures that the TOE authenticates devices it connects to.
P.DATA_CLASSIFICATION	This policy is directly implemented by O.DATA_CLASSIFICATION.
A.APP_DISTRIBUTION_PLATFORM	This assumption is directly implemented by OE.APP_DISTRIBUTION_PLATFORM.
A.CELLULAR_MOBILE_COMMUNICATION	This assumption is directly implemented by OE.CELLULAR_MOBILE_COMMUNICATION.
A.MINIMIZE_APP_DATA	This assumption is directly implemented by OE.MINIMIZE_APP_DATA
A.PASSWORD_PIN_PATTERN	This assumption is directly implemented by OE.PASSWORD_PIN_PATTERN.
A.TRUSTWORTHY_REMOTE_SERVICE	This assumption is directly implemented by OE.TRUSTWORTHY_REMOTE_SERVICE.
A.TRUSTWORTHY_UPDATE_SOURCE	This assumption is directly implemented by OE.TRUSTWORTHY_UPDATE_SOURCE.

7 Extended Components Definition

7.1 Definition of the Class FAP: Applications

7.1.1 Introduction

This class of requirements is focused on the risks associated with improperly designed applications. Applications are separate from the main operating system, though they may be included as part of the functionality provided on a consumer mobile device. Applications can provide unique attack vectors based on how they are designed and maintained on the device. The families relate to how applications are updated and configured.

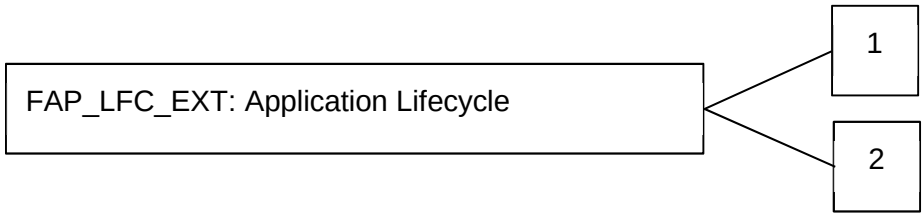


7.1.2 Definition of the family Application Lifecycle (FAP_LFC_EXT)

Family Behaviour

Applications need to be maintained to ensure flaws are corrected. This family defines requirements around how applications are updated and the actions that are taken when those updates are uninstalled (by the user).

Component Levelling



FAP_LFC_EXT.1 Preloaded applications are required to be updated to ensure flaws are remediated.

FAP_LFC_EXT.2 A preloaded application that is uninstalled will revert to the original version of the application contained in the system software. The user will be warned about using the original version and may have additional options or notices about using the application.

Management: FAP_LFC_EXT.1, FAP_LFC_EXT.2

There are no management activities foreseen.

Audit: FAP_LFC_EXT.1, FAP_LFC_EXT.2

There are no auditable events foreseen.

FAP_LFC_EXT.1 Preloaded application updates

Hierarchical to: No other components.

Dependencies: No dependencies.

FAP_LFC_EXT.1.1

The TSF shall ensure that preloaded applications are updated by [selection: *using an ADP and system software updates (to the version maintained in firmware), only by system software updates*].

FAP_LFC_EXT.2 Preloaded application update uninstall

Hierarchical to: No other components.

Dependencies: No dependencies.

FAP_LFC_EXT.2.1

The TSF shall warn the user when a preloaded application update is uninstalled and the application will revert to the version in the system software, and allow the following actions: [selection: *disable the application (where possible), warn the user on the next use, none*].

7.2 Definition of the family Cryptographic Key Hierarchy (FCS_CKH_EXT)

Family behaviour

This family describes the functional requirements for a cryptographic key hierarchy, a related set of keys that together protect data. Some keys in the key hierarchy will encrypt the data, while the other keys are used to encrypt and/or derive other keys in the key hierarchy. The sole security functional component is defined in an additional family (FCS_CKH_EXT) of the Class FCS (Cryptographic support). The component addresses the data that is protected, and how the keys in the key hierarchy are derived and protected.

Component levelling



FCS_CKH_EXT.1, Cryptographic key Hierarchy, requires definition of the key hierarchy and the data protected by the key hierarchy, and how the keys in the key hierarchy are derived and protected.

Management: FCS_CKH_EXT.1

There are no management activities foreseen.

Audit: FCS_CKH_EXT.1

There are no actions defined to be auditable.

FCS_CKH_EXT.1 Cryptographic Key Hierarchy

Hierarchical to:	No other components.
Dependencies:	[FCS_CKM.1 Cryptographic key generation, or FCS_COP.1 Cryptographic operation] FCS_CKM.6 Cryptographic Key Destruction.

FCS_CKH_EXT.1.1 The TSF shall support a key hierarchy for data encryption keys to protect [assignment: *list of data to be protected by the key hierarchy*].

FCS_CKH_EXT.1.2 The TSF shall ensure that all keys in key hierarchy are derived and/or generated according to [assignment: *description of how each key in the hierarchy is derived and/or generated, according to FCS_CKM.1/Symmetric, FCS_CKM.1/Asymmetric and/or FCS_CKM.5*] ensuring that the key hierarchy uses the DUK and [selection: *the user credentials, no user credentials*] directly or indirectly in the derivation of the data encryption key(s) for [assignment: *class of data assets*].

FCS_CKH_EXT.1.3 The TSF shall ensure that all keys in the key hierarchy and all data used in deriving the keys in the hierarchy are protected according to [assignment: *rules*].

User application notes

The selection in FCS_CKH_EXT.1.2 specifies how user credentials should be used to protect the user data assets. While the DUK is always used to tie the key hierarchy to the unique device, to tie data specifically to the user requires the user of the user credentials as part of the derivation process. The specification of the class of data assets will tie the type of protection offered to the specific data, such that any data tied to user credentials can only be accessed once the user is successfully authenticated.

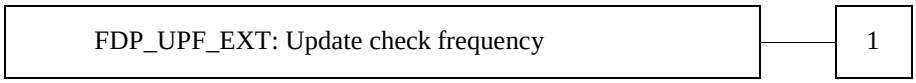
The protection assignment in FCS_CKH_EXT.1.3 can use protection methods like encryption by other keys in the key hierarchy, keys that are deleted after use and re-generated/re-derived when needed, or secure storage of the key (as specified in FPT_PHP.3).

7.3 Definition of the family Update Check Frequency (FDP_UPF_EXT)

Family behaviour

This family defines requirements for the frequency the TOE shall check for updates to apps or system software and actions if an update is available. The sole security functional component is defined in an additional family (FDP_UPF_EXT) of the Class FDP (User Data Protection).

Component levelling



FDP_UPF_EXT.1, Update check frequency, requires the TSF to provide an automatic check for updates of apps or system software. Rules defined by for the update process will determine the actions taken when an update is found.

Management: FDP_UPF_EXT.1

There are no management activities foreseen.

Audit: FDP_UPF_EXT.1

There are no actions defined to be auditable.

FDP_UPF_EXT.1 Update check frequency

Hierarchical to: No other components.

Dependencies: No dependencies.

FDP_UPF_EXT.1.1 The TSF shall be able to check for a [selection: *app, system software*] update package every [assignment: *interval period*].

User application notes

The assignment in FDP_UPF_EXT.1 specifies the frequency of the update check from the TOE. This does not mandate a successful connection which can be impacted by the network connectivity of the TOE during the period of the check. A check of the online status of the TOE before an attempt to connect to the update location is part of the update process.

7.4 Definition of Processed Data Minimisation (ADV_PDM_EXT)

This family addresses the assessment of the principle of data minimisation in the design of the TOE. This principle requires that the TOE processes (by storing, deriving, transforming, manipulating, importing or transmitting to out-of-TOE entities) only data that is necessary, adequate, relevant and limited to what is necessary in relation to the intended use of the TOE. The assessment of this principle in the TOE allows to ensure that the TOE does not perform processing of data that is not relevant to the intended purpose of the TOE.

Application notes:

In the context of this assurance family, data processing comprises two sets of data:

- User data assets that are provided as input to the TOE through any of its input interfaces.
- Operational data such as network telemetry data.

Within the context of the consumer mobile device, the TOE is the main OS, and the parts of the TOE that comprise the functionality provided by the main OS.

The justification that the TOE meets the data minimisation principle shall be supported in evidence provided by developers in which they shall declare which user and operational data is processed by the TOE. The AGD_OPE is used as supporting evidence, as it is meant describe all the data collected and how it may be utilized.

The developer evidence shall also demonstrate that all the user and operational data processed by the TOE is justifiably necessary and adequate in relation with the intended purpose of the TOE. The assessment of this characteristic of necessity and adequateness will require the evaluator to examine the intended use of the TOE in accordance with the TOE overview and TOE description described in the Security Target.

ADV_PDM_EXT.1: Processed Data Minimisation:

Dependencies: AGD_OPE.1 Operational user guidance

Developer action elements:

ADV_PDM_EXT.1.1D The developer shall design and implement the TOE so that it only processes user and operational data that is necessary and adequate in relation with the intended use of the TOE.

ADV_PDM_EXT.1.2D The developer shall provide a rationale for data minimisation of the TOE.

Content and presentation elements:

ADV_PDM_EXT.1.1C The rationale for data minimisation shall identify all user and operational data that is processed by the TOE.

ADV_PDM_EXT.1.2C The rationale for data minimisation shall demonstrate that all user and operational data processed by the TOE is necessary and adequate in relation with the intended purpose of the TOE.

Evaluator action elements:

ADV_PDM_EXT.1.1E The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

Evaluation of sub-activity (ADC_PDM_EXT.1)

Objectives:

The objective of this sub-activity is to determine whether the developer's design for minimisation of user and operational data within the context of the intended use of the TOE are adequately explained and justified.

Input:

The evaluation evidence for this sub-activity is:

a) the Security Target;

b) the guidance documentation.

Action ADV_PDM_EXT.1.1E

ADV_PDM_EXT.1-1 The evaluator ***shall examine*** that the rationale for data minimisation identifies all user and operational data that is processed by the TOE.

ADV_PDM_EXT.1-2 The evaluator ***shall examine*** the rationale for data minimisation and the operational user guidance, in order to determine that it provides descriptions of the user and operational data that is and is outputted to non-TOE entities. The data may not be input directly through any interfaces, it may be collected from the device itself and combined with the intended operations of the TOE.

ADV_PDM_EXT.1-3 The evaluator ***shall examine*** the rationale for data minimisation in order to determine that it demonstrates that all data processed by the TOE is necessary and adequate in relation with the intended purpose of the TOE.

7.5 Definition of the Documentation of security measures for device identifiers (ALC_DVS_EXT)

The security of a mobile device depends in part on several steps taken during the manufacturing process. Devices which are manufactured without proper controls on key security information may open the device to later unauthorized access.

Documentation of security measures for device identifiers (ALC_DVS_EXT) defines requirements for evaluator review of the manufacturing process related to how device identifiers and encryption keys are handled while they are installed on the TOE. Formally, ALC_DVS_EXT.0 is a precursor to ALC_DVS.1 as found in the catalogue in that it narrows the scope of the review to focus on the manufacturing process surrounding these keys and identifiers while removing the requirement for an onsite review of the manufacturing facilities.

This clause describes a component of the family Development security (ALC_DVS) for reviewing manufacturing steps in the creation of a mobile device around signing keys and the deployment of unique identifiers on the device.

Application notes:

The development security requirement ALC_DVS_EXT.0 focuses on the core security requirements surrounding the deployment of unique identifiers and keys to the device as well as the signing keys used on the software during manufacturing.

The evaluator performs a review of the documentation related to the manufacturing process and the organizational security policies that control access to the deployment of the keys and identifiers to the devices.

ALC_DVS_EXT.0 Documentation of security measures for device identifiers and keys:

Dependencies: No dependencies.

Developer action elements:

ALC_DVS_EXT.0.1D The developer shall produce and provide development security documentation on the generation, protection and use of signing keys.

ALC_DVS_EXT.0.2D The developer shall produce and provide development security documentation on the acquisition or generation of device unique identifiers.

Content and presentation elements:

ALC_DVS_EXT.0.1C The development security documentation shall describe all the physical, procedural, personnel, and other security measures that are necessary to protect the confidentiality and integrity of the keys used to sign the publicly released system software and its updates and to ensure the use of the proper keys in the build process.

ALC_DVS_EXT.0.2C The development security documentation shall describe the procedures for selecting the proper signing keys used for a device and to ensure the use of the proper keys in the build process.

ALC_DVS_EXT.0.3C The development security documentation shall describe all the physical, procedural, personnel, and other security measures that are necessary to protect the confidentiality and integrity of the unique, non-modifiable identifiers (such as IMEI, attestation keys or Device Unique Keys) are properly created and provisioned for each device.

Evaluator action elements:

ALC_DVS_EXT.0.1E The evaluator *shall confirm* that the information provided meets all requirements for content and presentation of evidence.

ALC_DVS_EXT.0.2E The evaluator *shall review* the provided evidence that the security measures are being applied.

Evaluation of sub-activity (ALC_DVS_EXT.0):

Objectives:

The objective of this sub-activity is to determine whether the developer's security controls on the development environment are adequate to provide the confidentiality and integrity of the TOE design and implementation that is necessary to ensure that secure operation of the TOE is not compromised.

Input:

The evaluation evidence for this sub-activity is:

a) the Security Target;

b) the development security documentation.

In addition, the evaluator may need to examine other deliverables to determine that the security controls are well-defined and followed. Evidence that the procedures are being applied is also required.

Action ALC_DVS_EXT.0.1E:

ALC_DVS_EXT.0-1 The evaluator ***shall examine*** the development security documentation to determine that it details all security measures used in the manufacturing environment that are necessary to protect the confidentiality and integrity of the TOE signing keys and unique, non-modifiable identifiers.

The evaluator determines what is necessary by first referring to the ST for any information that may assist in the determination of necessary protection.

If no explicit information is available from the ST the evaluator will need to make a determination of the necessary measures. In cases where the developer's measures are considered less than what is necessary, a clear justification should be provided for the assessment, based on a potential exploitable vulnerability.

The following types of security measures are considered by the evaluator when examining the documentation:

a) physical, for example physical access controls used to prevent unauthorized access to the TOE manufacturing environment (during normal working hours and at other times);

b) procedural, for example covering:

- granting of access to the manufacturing environment or to specific parts of the environment;
- revocation of access rights when a person leaves the manufacturing team;
- transfer of protected material within and out of the manufacturing environment and between different sites in accordance with defined acceptance procedures;
- admitting and escorting visitors to the manufacturing environment;
- roles and responsibilities in ensuring the continued application of security measures, and the detection of security breaches.

c) personnel, for example any controls or checks made to establish the trustworthiness of new manufacturing staff;

d) other security measures, for example the logical protections on any machines related to manufacturing.

The development security documentation should identify the locations at which manufacturing occurs, and describe the security measures applied at each location and for transports between different locations. For example, manufacturing may could occur at one facility while the keys and unique identifiers are acquired/generated at a different facility. Transport of information between facilities is covered by ALC_DVS_EXT.

ALC_DVS_EXT.0-2 The evaluator ***shall examine*** the manufacturing confidentiality policies in order to determine the sufficiency of the security measures employed.

The evaluator should examine whether the following is included in the policies:

a) which members of the manufacturing staff are allowed to access the various key and identifier materials;

b) how signing keys are generated, and which members are allowed to generate and assign keys to device models to be manufactured.

The evaluator should determine that these policies are described in the development security documentation, that the security measures employed are consistent with the policies, and that they are complete.

Action ALC_DVS_EXT.0.2E

ALC_DVS_EXT.0-3 The evaluator ***shall examine*** the development security documentation and associated evidence to determine that the security measures are being applied.

This work unit requires the evaluator to determine that the security measures described in the development security documentation are being followed, such that the integrity of the TOE and the confidentiality of associated documentation is being adequately protected. For example, this could be determined by examination of the documentary evidence provided.

8 Security requirements

8.1 Overview

This clause describes the security requirements which have to be fulfilled by the product under evaluation. Those requirements comprise functional components from Part 2 [20] and assurance components from Part 3 [21] of the Common Criteria.

8.2 Conventions

The following conventions are used for the completion of operations defined in the SFRs:

- Unaltered SFRs are stated in the form used in Part 2 [20] or their Extended Component Definition (ECD)
- Refinement made in the PP: the refinement text is indicated with **bold text** and ~~strikethroughs~~
- Selection wholly or partially completed in the PP: the selection values (i.e. the selection values adopted in the PP or the remaining selection values available for the ST) are indicated with underlined text.
  - e.g. '[selection: *disclosure, modification, loss of use*]' in Part 2 [20] or an ECD might become 'disclosure' (completion) or '[selection: disclosure, modification]' (partial completion) in the PP.
- Assignment wholly or partially completed in the PP: indicated with *italicized text*.
- Assignment completed within a selection in the PP: the completed assignment text is indicated with *italicized and underlined text*.
  - e.g. '[selection: change_default, query, modify, delete, [assignment: *other operations*]]' in Part 2 [20] or an ECD might become 'change_default, *select_tag'* (completion of both selection and assignment) or '[selection: change_default, *select_tag*, *select_value*]' (partial completion of selection, and completion of assignment) in the PP.
- Iteration: indicated by adding a string starting with '/' (e.g. 'FCS_COP.1/Hash')
- Extended SFRs are identified by having a label 'EXT' at the end of the SFR name

8.3 Security functional requirements

8.3.1 Applications (FAP)

FAP_LFC_EXT.1 Preloaded application updates

FAP_LFC_EXT.1.1 The TSF shall ensure that preloaded applications are updated by [selection: *using an ADP and system software updates (to the version maintained in firmware), only by system software updates*].

FAP_LFC_EXT.2 Preloaded application update uninstall

FAP_LFC_EXT.2.1 The TSF shall warn the user when a preloaded application update is uninstalled and the application will revert to the version in the system software, and allow the following actions: [selection: *disable the application (where possible), warn the user on the next use, none*].

Application note 1: The selection to warn the user on the next use is separate from the mandatory warning when the preloaded application updates are uninstalled. If the preloaded application does not support the updates uninstallation (e.g. the application can only be terminated or deactivated) and therefore does not revert it to the version in the system software, then this requirement is not applicable for that specific preloaded application. The requirement is not meant to be iterated for each preloaded application for when different options may be supported only on some actions. The requirement is limited to the preloaded application update uninstallation and it does not apply to the CMD recovery scenario (i.e. CMD factory reset).

8.3.2 Cryptographic Support (FCS)

A CMD under evaluation may support many cryptographic capabilities to provide the functionality expected by customers of the device. The cryptographic support of the TOE, as a subset of the overall functionality of the device, does not need to include capabilities which do not support the claims being made in the evaluation. The capabilities and algorithms specified in the requirements here only shall list those algorithms which are used to support requirements dependent on those algorithms.

A CMD may support a wide range of algorithms that can be used by calling apps and services. For the purposes of the evaluation, only those algorithms that are used by the CMD to support claimed security functions shall be enumerated and evaluated here. While the cryptographic algorithms used for the evaluation are not specified, they are expected to meet a minimum level of strength, generally defined as being equivalent to 128-bit block cipher encryption.

The requirements do not specify a catalogue of algorithms to choose from, but instead focus on the traits of algorithms that would be considered acceptable. An example catalog of algorithms that would be considered acceptable is the ECCG Agreed Cryptographic Mechanisms - version 2 [i.15] document. Quantum safe algorithms and discussions about post quantum concerns are laid out in this reference document.

A CMD may support multiple key hierarchies depending on the root key(s) used for security of the hierarchy. The design of the key hierarchies shall be specified as to how the requirements specified here are met. The key hierarchy requirements focus on how the keys are tied to the root key(s) and how they are used for protection of data, not how they are designed or the number of hierarchies used to meet the individual requirements.

FCS_CKH_EXT.1/Low Cryptographic key hierarchy

FCS_CKH_EXT.1.1/Low The TSF shall support a key hierarchy for data encryption keys to protect [*low user data assets*].

FCS_CKH_EXT.1.2/Low The TSF shall ensure that all keys in the key hierarchy are derived and/or generated according to [*assignment: description of how each key in the hierarchy is derived and/or generated, according to FCS_CKM.1/Symmetric, and/or FCS_CKM.5*] ensuring that the key hierarchy uses the DUK and [no user credentials] directly or indirectly in the derivation of the data encryption key(s) for [*low user data assets*].

FCS_CKH_EXT.1.3/Low The TSF shall ensure that all keys in the key hierarchy and all data used in deriving the keys in the hierarchy are protected according to [*assignment: rules*].

FCS_CKH_EXT.1/MediumHigh Cryptographic key hierarchy

FCS_CKH_EXT.1.1/MediumHigh The TSF shall support a key hierarchy for data encryption keys to protect [*medium and high user data assets*].

FCS_CKH_EXT.1.2/MediumHigh The TSF shall ensure that all keys in the key hierarchy are derived and/or generated according to [assignment*: description of how each key in the hierarchy is derived and/or generated, according to FCS_CKM.1/Symmetric, FCS_CKM.1/Asymmetric and/or FCS_CKM.5*] ensuring that the key hierarchy uses the DUK and [the user credentials] directly or indirectly in the derivation of the data encryption key(s) for [*medium and high user data assets*].

FCS_CKH_EXT.1.3/MediumHigh The TSF shall ensure that all keys in the key hierarchy and all data used in deriving the keys in the hierarchy are protected according to [*assignment: rules*].

FCS_CKM.1/Asymmetric Cryptographic key generation

FCS_CKM.1.1/Asymmetric The TSF shall generate cryptographic keys in accordance with a specified cryptographic key generation algorithm [*assignment: asymmetric cryptographic key generation algorithm*] and specified cryptographic key sizes [*assignment: cryptographic key sizes equal to or greater than 128-bit symmetric keys*] that meet the following: [*assignment: a public cryptographic standard that meets the qualification criteria for new ciphers as specified in ISO/IEC 18033-1* [17] *Annex A*].

FCS_CKM.1/Symmetric Cryptographic key generation

FCS_CKM.1.1/Symmetric The TSF shall generate cryptographic keys in accordance with a specified cryptographic key generation algorithm [selection: *for symmetric encryption using a random number generator as specified in FCS_RBG.1, for symmetric encryption a combination of precursor key material using a derivation function as specified in FCS_CKM.5*] and specified cryptographic key sizes [*assignment: cryptographic key sizes equal to or greater than 128-bit symmetric keys*] ~~that meet the following: [**assignment:** *list of standards*~~].

FCS_CKM.5 Cryptographic key derivation

FCS_CKM.5.1 The TSF shall derive cryptographic keys [*assignment: key type*] from [*assignment: input parameters*] in accordance with a specified key derivation algorithm [*assignment: key derivation algorithm*] and specified cryptographic key sizes [*assignment: cryptographic key sizes equal to or greater than 128-bit symmetric keys*] that meet the following: [*assignment: a public cryptographic standard that meets the qualification criteria for new ciphers as specified in ISO/IEC 18033-1* [17] *Annex A*].

Application Note 2: Examples of derivation functions algorithms are: PBKDF, NIST Special Publication 800-108 KDF.

FCS_CKM.6 Timing and event of cryptographic key destruction

FCS_CKM.6.1 The TSF shall destroy [*assignment: list of cryptographic keys (including keying material)*] when [selection: *no longer needed, [assignment: other circumstances for key or keying material destruction]*].

FCS_CKM.6.2 The TSF shall destroy cryptographic keys and keying material specified by FCS_CKM.6.1 in accordance with a specified cryptographic key destruction method [

- *for volatile memory, by a single direct overwrite consisting of [*selection: *a random pattern, using the TSF's RNG, zeroes];*
- *for non-volatile eeprom, by a single direct overwrite consisting of a random pattern, using the TSF's rng, followed by a read-verify;*
- *for non-volatile flash memory, that is not wear-levelled, by [*selection: *a single direct overwrite consisting of zeros followed by a read-verify, a block erase that erases the reference to memory that stores data as well as the data itself];*
- *for non-volatile flash memory, that is wear-levelled, by [*selection: *a single direct overwrite consisting of zeros, a block erase];*
- *for non-volatile memory other than eeprom and flash, by a single direct overwrite with a random pattern that is changed before each write*];

that meets the following: [*assignment: list of standards*].

Application Note 3: When no standard is applicable in the assignment, it can be left none.

FCS_COP.1/Hash Cryptographic operation

FCS_COP.1.1/Hash The TSF shall perform [*cryptographic hashing*] in accordance with a specified cryptographic algorithm [*assignment: cryptographic algorithm*] and cryptographic key sizes [*none*] that meet the following: [*assignment: a public cryptographic standard that meets the qualification criteria for new ciphers as specified in ISO/IEC 18033-1* [17] *Annex A*].

Application Note 4: Examples of hash algorithms are: SHA2 or SHA3.

FCS_COP.1/KeyedHash Cryptographic operation

FCS_COP.1.1/KeyedHash The TSF shall perform [*keyed-hash message authentication*] in accordance with a specified cryptographic algorithm [*assignment: cryptographic algorithm*] and cryptographic key sizes [*assignment: cryptographic key sizes*] that meet the following: [*assignment: a public cryptographic standard that meets the qualification criteria for new ciphers as specified in ISO/IEC 18033-1* [17] *Annex A*].

Application Note 5: Examples of hashed message authentication algorithms are: HMAC-SHA2 or KMAC256.

FCS_COP.1/KeyEst Cryptographic operation

FCS_COP.1.1/KeyEst The TSF shall perform [*cryptographic key establishment*] in accordance with a specified cryptographic algorithm [*assignment: cryptographic key establishment scheme algorithm*] and cryptographic key sizes [*assignment: cryptographic key sizes equal to the key sizes being used for encryption*] that meet the following: [*assignment: a public cryptographic standard that meets the qualification criteria for new ciphers as specified in ISO/IEC 18033-1* [17] *Annex A 17]*].

Application Note 6: Examples of key establishment schemes are: NIST Special Publication 800-56Ar3 for Pair-Wise Key Establishment.

FCS_COP.1/SigGen Cryptographic operation

FCS_COP.1.1/SigGen The TSF shall perform [*cryptographic signature services (generation and verification)*] in accordance with a specified cryptographic algorithm [*assignment: cryptographic algorithm*] and cryptographic key sizes [*assignment: cryptographic key sizes equal to or greater than 128-bit symmetric keys*] that meet the following: [*assignment: a public cryptographic standard that meets the qualification criteria for new ciphers as specified in ISO/IEC 18033-1* [17] *Annex A*].

Application Note 7: Examples of signature generation/verification algorithms are: RSA or ECDSA.

FCS_COP.1/Symmetric Cryptographic operation

FCS_COP.1.1/Symmetric The TSF shall perform [*symmetric encryption and decryption*] in accordance with a specified cryptographic algorithm [*assignment: cryptographic algorithm*] and cryptographic key sizes [*assignment: cryptographic key sizes equal to or greater than 128-bit symmetric keys*] that meet the following: [*assignment: a public cryptographic standard that meets the qualification criteria for new ciphers as specified in ISO/IEC 18033-1* [17] *Annex A.*

Application Note 8: Examples of symmetric algorithms are: AES or Camellia.

FCS_RBG.1 Random bit generation

FCS_RBG.1.1 The TSF shall perform deterministic random bit generation services using [*assignment: DRBG algorithm*] in accordance with [*assignment: a public cryptographic standard that meets the qualification criteria for new ciphers as specified in ISO/IEC 18033-1* [17] *Annex A*] after initialization.

FCS_RBG.1.2 The TSF shall use a [*TSF as specified in FCS_RBG.3.1*] for initialization and reseeding.

FCS_RBG.1.3 The TSF shall update the DRBG state by [selection: *reseeding, uninstantiating and re-instantiating*] using a [*TSF entropy source as specified in FCS_RBG.3.1*] in the following situations: [selection:

- *never;*

- *on demand;*
- *on the condition: [assignment: condition];*
- *after [assignment: time]*]

in accordance with [*assignment: a public cryptographic standard that meets the qualification criteria for new ciphers as specified in ISO/IEC 18033-1* [17] *Annex A*].

FCS_RBG.3 Random bit generation (internal seeding – single source)

FCS_RBG.3.1 The TSF shall be able to seed the DRBG using a [selection: choose one of: *TSF software-based entropy source, TSF hardware-based entropy source][assignment: name of entropy source]]* with a [*assignment: number of bits*] bits of min-entropy.

Application Note 9: While it is possible that multiple sources may be used to seed the RBG, for the purposes of the TOE as a whole, the combination will be utilized as a single source. The output of the DRBG specified in FCS_RBG.1.1 will show how the min-entropy bits provided from the noise source are sufficient to generate keys of at least 128-bit entropy.

8.3.3 User Data Protection (FDP)

8.3.3.1 Monitoring

FDP_SDI.1 Stored data integrity monitoring

FDP_SDI.1.1 The TSF shall monitor user data stored in containers controlled by the TSF for [*integrity errors*] on all objects, based on the following attributes: [*modifiable keys or parameters stored according to FPT_PHP.3*].

Application Note 10: Keys or parameters stored according to the requirements in FPT_PHP.3 may be either fixed (such as write-once) or modifiable. Modifiable keys or parameters need to be stored to protect their integrity. This includes keys or parameters loaded by the TOE manufacturer as well as by the user into any storage area protected by FPT_PHP.3.

8.3.3.2 The Update Policy

The Update Policy defines:

- How often the TSF will check whether new app or system software updates are available.
- Depending on the package type, it can install a new app or update either a single app or portions of the system software.
- The conditions under which the TSF uses update packages to install newer versions of the app or system software.

The Update Policies define the following objects, attributes and operations:

Objects:

- App: any application to be installed or updated.
- App_Install_Package: the file(s) that contain the app to be installed
- App_Update_Package: the file(s) that contain a new version of an installed app.
- User_Data: user data assets, created or placed on the device from the point of the initial CMD setup.
- SSW: the system software of the TOE.
- SSW_Update_Package: the file(s) that contain a new version of the system software.

Attributes:

- App_Name: the name of the app, as defined by the App Developer.
- Version_ID: the version identifier of the app, system software or update package.
- Signature: the cryptographic signature associated with, as applicable, the app (or App Developer), system software or update package is valid according to appropriate platform requirements.
- Package_Source: the location where the Update_Package is acquired from (from the standpoint of the TSF).

Device_Identifier: information about the device and proper authorization to access the service providing the SSW_Update_Package.Operations:

- Install_App: The initial installation process for a new app.
- Update_App: The update process for installing the new version of the application.
- Update_SSW: The update process for installing a new version of the system software.
- Upload: The process of sending data to the service where the SSW_Update_Package is downloaded from.

FDP_ACC.1/APP_Install Subset access control

FDP_ACC.1.1/APP_Install The TSF shall enforce the [*App_Install Policy*] on [*subjects: the TSF, objects: App, App_Install_Package, operations: Install_App*].

Application Note 11: The Object "App" is used here generically to mean any app that can be installed through the ADP (downloaded or preinstalled).

FDP_ACF.1/APP_Install Security attribute based access control

FDP_ACF.1.1/APP_Install The TSF shall enforce the [*App_Install Policy*] to objects based on the following: [*subjects: the TSF, objects[attributes]: App[Version_ID, Signature], App_Install_Package[Version_ID, Signature, Package_Source]*].

Application Note 12: The Object "App" is used here generically to mean any app that can be updated through the ADP (downloaded or preinstalled).

FDP_ACF.1.2/APP_Install The TSF shall enforce the following rules to determine if an operation among controlled subjects and controlled objects is allowed: [

- *the TSF shall allow the TSF to Install_App with an App_Install_Package only if:*
  - *the TSF successfully verifies the signature of the App_Install_Package and the Signature is valid according to the platform requirements;*
  - *the TSF does not find an existing app where the [attribute]: App_Name matches the new app;*
  - *the Package_Source is not the ADP of the TOE manufacturer, that the user has explicitly authorized the TSF to perform the installation;*
- *the TSF Install_App is an atomic installation function*].

Application Note 13: Version_ID tracking is only available for currently installed apps, so if a user uninstalls an app it is possible for the user to install any version of the app, including older ones than what was uninstalled, as the process of uninstalling the app removes any reference for the version_ID comparison.

FDP_ACF.1.3/APP_Install The TSF shall explicitly authorize access of subjects to objects based on the following additional rules: [*assignment: other rules ensuring authenticity and integrity of the install package*].

FDP_ACF.1.4/APP_Install The TSF shall explicitly deny access of subjects to objects based on the following additional rules: [*the TSF shall not allow any TSF-mediated actions related to the Install_App operation or access to the App during its installation is complete*].

FDP_ACC.1/APP_Update Subset access control

FDP_ACC.1.1/APP_Update The TSF shall enforce the [*App_Update Policy*] on [*subjects: the TSF, objects: App, App_Update_Package, operations: Update_App*].

Application Note 14: The Object "App" is used here generically to mean any app that can be updated through the ADP (downloaded, preinstalled or preloaded).

FDP_ACF.1/APP_Update Security attribute based access control

FDP_ACF.1.1/APP_Update The TSF shall enforce the [*App_Update Policy*] to objects based on the following: [*subjects: the TSF, objects[attributes]: App[Version_ID, Signature], App_Update_Package[Version_ID, Signature, Package_Source]*].

Application Note 15: The Object "App" is used here generically to mean any app that can be updated through the ADP (downloaded, preinstalled or preloaded).

FDP_ACF.1.2/APP_Update The TSF shall enforce the following rules to determine if an operation among controlled subjects and controlled objects is allowed: [

- *the TSF shall allow the TSF to Update_App with an App_Update_Package only if:*
  - *the TSF finds an existing installed App where the [attribute: App_Name] matches;*
  - *the TSF successfully verifies the signature of the App_Update_Package and the Signature is from the same App or App Developer;*
  - *[*selection: *the Version_ID of the App_Update_Package is not lower than the Version_ID of the installed App*, *the update is downloaded from the App Distribution Platform of the TOE Manufacturer or OS Developer];*
- *the TSF Update_App is an atomic update function*].

Application Note 16: Version_ID tracking is only available for currently installed apps, so if a user uninstalls an app it is possible for the user to install any version of the app, including older ones than what was uninstalled, as the process of uninstalling the app removes any reference for the version_ID comparison.

FDP_ACF.1.3/APP_Update The TSF shall explicitly authorize access of subjects to objects based on the following additional rules: [*assignment: other rules ensuring authenticity and integrity of the update package*].

FDP_ACF.1.4/APP_Update The TSF shall explicitly deny access of subjects to objects based on the following additional rules: [*the TSF shall not allow any TSF-mediated actions related to the Update_App operation or access to the App during its updating*].

FDP_UPF_EXT.1/APP_Update Update check frequency

FDP_UPF_EXT.1.1/APP_Update The TSF shall be able to check for a [App] update package every [assignment: *interval period of no more than 1 day*].

FDP_ACC.2/SSW_Update Complete access control

FDP_ACC.2.1/SSW_Update The TSF shall enforce the [*SSW_Update Policy*] on [*subjects: the TSF, objects: the SSW, SSW_Update_Package, User Data, operations: Update_SSW, Upload*].

FDP_ACC.2.2/SSW_Update The TSF shall ensure that all operations between any subject controlled by the TSF and any object controlled by the TSF are covered by an access control SFP.

FDP_ACF.1/SSW_Update Security attribute based access control

FDP_ACF.1.1/SSW_Update The TSF shall enforce the [*SSW_Update Policy*] to objects based on the following: [*subjects: the TSF, objects[attributes]: User Data[none], SSW[Version_ID, Signature], SSW_Update_Package[Version_ID, Signature, Package_Source, Device_Identifier]*].

FDP_ACF.1.2/SSW_Update The TSF shall enforce the following rules to determine if an operation among controlled subjects and controlled objects is allowed: [

- *the TSF is allowed to perform the Update_SSW operation if the following conditions hold:*
  - *the SSW_Update_Package[Device_Identifier] is authorized for the download;*
  - *[*selection: *the SSW_Update_Package[Version_ID] is not lower than the SSW[Version_ID], the SSW_Update[Package_Source] is the trustworthy update source directly];*
  - *the SSW_Update_Package[Signature] is verified by a digital signature from the TOE Manufacturer stored on the device;*
  - *the Signature check and the Update_SSW are performed as an atomic update function]*.

FDP_ACF.1.3/SSW_Update The TSF shall explicitly authorize access of subjects to objects based on the following additional rules: [*assignment: other rules ensuring authenticity and integrity of the update package*].

FDP_ACF.1.4/SSW_Update The TSF shall explicitly deny access of subjects to objects based on the following additional rules: [

- *Operation Update_SSW:* the TSF shall not allow any TSF-mediated actions related to the Update_SSW function during its updating].
- *Operation Upload: the TSF shall not allow any access to User_Data not necessary to fulfill the Attribute Device_Identifier*].

Application Note 17: Failure of correct installation of the update is handled in FPT_FLS.1. The update process will require a check that the CMD and maybe also the user account are authorized to download the SSW_Update_Package, to ensure the proper update package is provided for the device. The Device_Identifier attribute is specified to detail this minimal set of information necessary to authorize the proper download.

FDP_UPF_EXT.1/SSW_Update Update check frequency

FDP_UPF_EXT.1.1/SSW_Update The TSF shall be able to check for a [system software] update package every [*assignment: interval period of no more than 1 month*] and provide a notification to the user when an update is available.

8.3.3.3 The Permissions Policy

The Permissions Policy defines the access of apps and processes to objects outside its own security domain. The permissions can range from user-oriented controls, such as access to the camera, microphone, and address book, to more explicit access to underlying functionality in the main OS, such as to files, secure IPCs and secure sockets.

User Objects and Manufacturer Objects are defined by whether the user actually has the ability to change the access to the object. Access control lists related to User Objects can be managed by the user, while access control lists related to Manufacturer Objects can only be managed by the TOE manufacturer.

User Objects focus on access to system components and services which the user normally sees as permissions, such as to the camera or contacts. Even when assigned from the TOE manufacturer by default these permissions can be changed by the user (though changing TOE manufacturer-assigned permissions can have unintended consequences to the capabilities of the device). The permission/revocation of this access to User Objects is defined in FMT_SMF.1/Permissions.

Manufacturer Objects focus on access to the underlying system components and services which the user does not have direct access to and cannot change. These objects provide controls that ensure apps or processes only have access to their own defined security domain using and usually controlled by the main OS kernel. The Manufacturer Objects may provide the underlying capabilities which the user sees as permissions, but also enforces the boundary of the app or process around the overall security domain.

Of the Manufacturer Objects defined in the requirement, system permissions is a general list of access rights that control functions of the main OS that can only be assigned by the TOE manufacturer. As a Manufacturer Object, the user does not have the ability control the permissions set by the TOE manufacturer.

FDP_ACC.2/Permissions Complete access control

FDP_ACC.2.1/Permissions The TSF shall enforce the [*permissions policy*] on [

- *subjects: Apps, Processes;*
- *user objects: [*selection: camera, microphone, location, contacts, calendar, call log, stored pictures, text messages, the list of installed apps*, [assignment: list of other sensitive user data assets and/or system services that can be accessed by an App or Process]];*
- *manufacturer objects: device ID, system permissions, files (including individual app data), [*selection*: secure sockets, secure IPC, [assignment: list of other sensitive user data assets and/or system services that can be accessed by an App or Process]];*
- *operations: read, write, execute*].

Application Note 18: If a device supports a specific User Object, it shall be selected.

Terminology used for Manufacturer Objects can be defined in the assignment if secure sockets and secure IPC are not relevant terms.

The TOE manufacturer may assign a User Object permission to a privileged app or process that cannot be changed by the user. If this is done, the app or process and the User Object shall be specified in the Manufacturer Objects assignment and for the purposes of that app or process, the permission is considered a Manufacturer Object.

The TOE manufacturer establishes the permissions for app data to ensure that apps are restricted from accessing the data from another app except under specific circumstances (such as apps from a common App Developer).

FDP_ACC.2.2/Permissions The TSF shall ensure that all operations between any subject controlled by the TSF and any object controlled by the TSF are covered by an access control SFP.

FDP_ACF.1/Permissions Security attribute based access control

FDP_ACF.1.1/Permissions The TSF shall enforce the [*permissions policy*] to objects based on the following: [

- *[Apps and Processes] and the operations associated with the subject;*
- *the access control list associated with the object being requested*].

FDP_ACF.1.2/Permissions The TSF shall enforce the following rules to determine if an operation among controlled subjects and controlled objects is allowed: [

- *the subject, or a grouping the subject is mapped to, is explicitly granted permission by the user or TOE manufacturer to the user object in the access control list*].

FDP_ACF.1.3/Permissions The TSF shall explicitly authorize access of subjects to objects based on the following additional rules: [

- *the subject is granted permission by the TOE manufacturer to the manufacturer object in the access control list;*
- *the subject is explicitly granted by the user to access the user object;*
- *granted by the user when the permission is requested*.

Application Note 19: Permissions may be granted by the user at any time. Persistently granted permissions will not require the user to re-approve access to the permission, while temporary granted permissions will require re-approval based on the system capabilities.

Per the rules, the second rule is for persistently approved permissions, while the third rule is for any permission that is requested that has not been persistently approved (whether this is because access is being requested for the first time, or because it was not granted persistent approval does not matter).

FDP_ACF.1.4/Permissions The TSF shall explicitly deny access of subjects to objects based on the following additional rules: [

- *the subject is explicitly blocked by the user from accessing the user object;*
- *there is no rule granting the subject access to the user or TOE manufacturer object in the access control list*].

8.3.3.4 The Data Classification Policy

The Data Classification Policy defines how access to encrypted data is controlled. In this case, the only operation is to decrypt data that has already been stored. This policy enforces the encryption of user data as specified in FCS_CKH_EXT.1 for different classifications of user data.

The policy defines the following subjects, objects, attributes and operations:

Subjects:

- The TSF

Objects:

- Internal storage objects holding user data

Attributes:

- Classification of the user data

Operations:

- Decryption

FDP_ACC.1/UserDataAsset Subset access control

FDP_ACC.1.1/UserDataAsset The TSF shall enforce the [*user data asset decryption policy*] on [

- *subjects: the TSF;*
- *objects: internal storage (all saved user data assets);*
- *operations: decrypt*].

FDP_ACF.1/UserDataAsset Security attribute based access control

FDP_ACF.1.1/UserDataAsset The TSF shall enforce the [*user data asset decryption policy*] to objects based on the following: [*subjects: the TSF, objects: user data assets, attributes: classification level of objects, low, medium, high*].

FDP_ACF.1.2/UserDataAsset The TSF shall enforce the following rules to determine if an operation among controlled subjects and controlled objects is allowed: [

- *the TSF is allowed to decrypt low user data assets as specified in FCS_CKH_EXT.1/Low if and only if the TOE is successfully powered on;*
- *the TSF is allowed to decrypt medium user data assets as specified in FCS_CKH_EXT.1/MediumHigh if and only if the TOE is successfully powered on and the user is successfully authenticated during the first authentication after power on;*
- *the TSF is allowed to decrypt high user data assets as specified in FCS_CKH_EXT.1/MediumHigh if and only if the TOE is successfully powered on, the user is successfully authenticated and the screen of the TOE is not locked*].

Application Note 20: The phrase "successfully powered on" means that the TOE has successfully booted up and completed all tests required by FPT_TST.1.

FDP_ACF.1.3/UserDataAsset The TSF shall explicitly authorize access of subjects to objects based on the following additional rules: [*no additional rules*].

FDP_ACF.1.4/UserDataAsset The TSF shall explicitly deny access of subjects to objects based on the following additional rules: [*no additional rules*].

8.3.4 Identification and Authentication (FIA)

FIA_UAU.1 Timing of authentication

FIA_UAU.1.1 The TSF shall allow [assignment: *list of TSF-mediated actions not accessing user data asset stored before the action is performed unless permitted by the user*] on behalf of the user to be performed before the user is authenticated.

Application Note 21: Actions not listed in the assignment are not allowed before user authentication.

The actions in FIA_UAU.1.1 can include taking a picture and making an emergency call.

FIA_UAU.1.2 The TSF shall require the user to be successfully authenticated before allowing any other TSF-mediated actions on behalf of that user.

FIA_UID.1 Timing of identification

FIA_UID.1.1 The TSF shall allow [assignment: *list of TSF-mediated actions not accessing user data asset stored before the action is performed unless permitted by the user*] on behalf of the user to be performed before the user is identified.

FIA_UID.1.2 The TSF shall require each user to be successfully identified before allowing any other TSF-mediated actions on behalf of that user.

FIA_UAU.5/Local Multiple authentication mechanisms

FIA_UAU.5.1/Local The TSF shall provide [*password, PIN and [*selection: *pattern, BAF, [assignment: EAF], no other mechanism]*] to support user authentication.

Application Note 22: Use of an EAF assumes that the EAF is trusted by the user and so its security is out of scope of the evaluation. The use of the EAF shall be described and the connection to the TOE shall be stated (for example, over a wired connection or the particular wireless protocol used).

FIA_UAU.5.2/Local The TSF shall authenticate any user's claimed identity according to the [*assignment: rules describing how the multiple authentication mechanisms provide authentication*].

Application Note 23: Rules can be: "Always try password authentication first", "Always require both password and EAF authentication", "User chooses which mechanism to use", etc.

FIA_UAU.5/Peer Multiple authentication mechanisms

FIA_UAU.5.1/Peer The TSF shall provide **support to use** [selection: *explicit acceptance of connection, QR codes, NFC labels, PINs, using a common user account to a remote service on both devices*, [*assignment: other mechanism to verify the peer identity*]] **for** ~~to support user~~ authentication **to peer devices before allowing any actions on behalf of the user**.

Application Note 24: Explicit acceptance of connection means the user of the device has entered an approval into the interface of the TOE. Use of QR codes, NFC labels and PINs can be in either direction, either generating the invitation to connect or responding. For example the TSF can generate a QR code that can be shared with the peer device, or it could scan the QR code from the peer.

Bluetooth® authentication is handled as part of FTP_ITC_EXT.1/BT, WLAN authentication is handled as part of FTP_ITC_EXT.1/WLAN and their requirements do not need to be duplicated here.

FIA_UAU.5.2/Peer The TSF shall authenticate any ~~user's~~ **peer device's** claimed identity according to the [assignment: *rules describing how the multiple authentication mechanisms provide peer device authentication*].

FIA_UAU.6 Re-authenticating

FIA_UAU.6.1 The TSF shall re-authenticate the user under the conditions [

- *attempted change of any user authentication factor;*
- *attempted unlocking of a locked TOE;*
- *[*selection: *when changing user accounts using the credentials for the new user*, *using no credentials for a guest user*, *[assignment: other conditions]*, *no other conditions]*].

Application Note 25: The selections of "when changing user accounts using the credentials for the new user" or "using no credentials for a guest user" require including the requirements from the PP-Module for Multi-User Support.

FIA_UAU.7 Protected authentication feedback

FIA_UAU.7.1 The TSF shall provide only [*brief feedback about the entered credentials*] to the user while the authentication is in progress.

FIA_SOS.1 Verification of secrets

FIA_SOS.1.1 The TSF shall provide a mechanism to verify that secrets meet [

- *for password and PIN: length of 4 or more from a defined character set;*
- *for patterns: consists of at least 4 from a set of at least 9 available points, where each point shall only be used once*].

Application Note 26: The user takes care of the complexity of the PIN/Password: how easy it is to guess for others. See OE.PASSWORD_PIN_PATTERN.

The TOE can provide an indication of the complexity of the password/PIN to assist user in selecting passwords/PINS that are not easy to guess.

FIA_AFL.1 Authentication failure handling

FIA_AFL.1.1 The TSF shall detect when [*an integer between 3 and 10*] unsuccessful authentication attempts occur related to [selection: *password*, *PIN*, *pattern*, *BAF*, *EAF*].

FIA_AFL.1.2 When the defined number of unsuccessful authentication attempts has been [met], the TSF shall [selection: *reboot*, *progressively lengthen the time to attempt an authentication*, *make all user data assets unreadable*, *[assignment: list of other actions to reduce the risk of attacks such as brute-force attack]*].

8.3.5 Security Management (FMT)

As the CMD is not a managed device in the enterprise sense, all management is handled locally by the user as opposed to a specific management service as would be the case for an enterprise device.

FMT_MSA.1/Permissions Management of security attributes

FMT_MSA.1.1/Permissions The TSF shall enforce the [*permissions policy*] to restrict the ability to [selection: *approve persistently*, *approve temporarily*, *reject persistently*, *reject temporarily*, modify, *[assignment: other operations]*] the security attributes [*list of user objects*] to [*the current user for their own permissions*].

FMT_MSA.3/Permissions Static attribute initialization

FMT_MSA.3.1/Permissions The TSF shall enforce the [*permissions policy*] to provide [restrictive] default values for security attributes that are used to enforce the SFP.

FMT_MSA.3.2/Permissions The TSF shall allow the [*current user for their own permissions*] to specify alternative initial values to override the default values when an object or information is created.

Application Note 27: "restrictive" is chosen here as the default condition is that no permissions should be allowed unless authorized by the user or the TOE manufacturer.

FMT_SMF.1/Authentication Specification of Management Functions

FMT_SMF.1.1/Authentication The TSF shall be capable of performing the following management functions: [

- *ability to enter an initial or change (including removal of) the KAF,*
- *ability to configure the inactivity timeout period before the user is required to enter credentials again,selection: [*
  - *ability to enrol or change (including removal of) the BAF,*
  - *ability to register or change (including removal of) the EAF,*
  - *ability to show the length of the credential the user is requested to enter during authentication,*
  - *no other functions].*

Application Note 28: The details of the BAF are specified in ETSI TS 103 732-2 [i.16] requirements.

FMT_SMF.1/APP_Update Specification of Management Functions

FMT_SMF.1.1/APP_Update The TSF shall be capable of performing the following management functions: [

- *ability to specify to [*selection*: notify the user without downloading, notify the user after downloading, automatically install] when an automatic check to the ADP has found an update;*
- *ability to initiate an immediate check for update;*
- *ability to initiate an update of the app (if available);*
- *ability to display the version number of the app;*
- *ability to install an app (downloaded apps);*
- *ability to uninstall downloaded apps (including preinstalled apps and remove the associated (not shared) data)*].

Application Note 29: The selection for setting the automatic update check may provide only a single option such that the user does not have the ability to make a specific choice based on the options available on the TOE.

Application Note 30: Shared data for apps is data specifically stored outside the app data location to be seen or accessed by other apps or provided as shared resources across the device. For example the photos stored on the device are usually stored in a shared location when taken by the built-in camera, while photos taken inside an app may only be stored within the app storage location. The first would be shared and not deleted while the second would be app-specific and deleted with the app uninstall.

FMT_SMF.1/Permissions Specification of Management Functions

FMT_SMF.1.1/Permissions The TSF shall be capable of performing the following management functions: [

- *ability to view permissions granted to an app;*
- *ability to grant/revoke permission to/from an app or process to have read and/or write access to a user object*].

Application Note 31: User Object is defined in FDP_ACC.2.1/Permissions.

FMT_SMF.1/Privacy Specification of Management Functions

FMT_SMF.1.1/Privacy The TSF shall be capable of performing the following management functions: [selection:

- *ability to change or reset the privacy aliases*,
- *ability to block the creation/use of a unique id for advertising (no personalized tracking)*].

Application Note 32:These aliases are defined in clause 8.3.6.

The change of alias can be explicit (for instance by providing a specific option in the app or in the TOE) or implicit (for instance rebooting the TOE or uninstalling/reinstalling an app automatically generates a new alias).**FMT_SMF.1/SSW_Update Specification of Management Functions**

FMT_SMF.1.1/SSW_Update The TSF shall be capable of performing the following management functions: [

- *ability to specify to [*selection: *notify the user without downloading, notify the user after downloading, automatically install] when an automatic check to the trustworthy update source has found an update;*
- *ability to initiate an immediate check for update;*
- *ability to initiate an update of the system software (if available);*
- *ability to provide the status of the update process and the results of the update;*
- *ability to [*selection*: delay temporarily, block persistently] automatic installation of system software updates;*
- *ability to display the version number of the system software*].

Application Note 33: The selection for setting the automatic update check may provide only a single option such that the user does not have the ability to make a specific choice based on the options available on the TOE.

FMT_SMF.1/UserControls Specification of Management Functions

FMT_SMF.1.1/UserControls The TSF shall be capable of performing the following management functions: [

- *ability to grant/revoke permission to/from downloaded app or preinstalled app without system permission to have access to accessibility service;*
- *ability to grant/revoke permission to/from an app or process to have access to device notifications;*
- *ability to perform a factory reset that will place the device at the beginning of the initial CMD setup process;*
- *ability to specify [*selection: *charge only mode by default, file transfer mode, [assignment: other wired connection mode]] when the TOE is connected via the wired interface to another device;*
- *[*selection: *enable/disable removable media encryption, no support for removable media];*
- *[*selection: *ability to approve AT modem commands through [*selection: *individual command approval, session-based approval] when sent from [*selection: *wired connection, remote connection, [*assignment: *other interface]], AT modem commands are not allowed to be triggered from any external connection, no AT modem commands are supported];*
- *[*selection: *provide a method for directly transferring data to a new device (wired or wireless), provide a method for backing up data to be restored on a new device, not provide a built-in service to backup and restore data];*
- *[*selectin: *provide a method to enable/disable NFC, [*assignment: *other methods for controlling NFC access], no support for NFC];*
- *[assignment: list of management functions to be provided by the TSF]*].

Application Note 34: The selection for charging mode is per connection basis, and the "charge only mode" is the default mode when the user does not select any mode.

Application Note 35: The selection for AT modem commands is focused on the ability to receive AT modem commands directly from a remote connection. The primary restriction here is to ensure that if remote AT commands can be sent, that they are specifically authorized (such as per command, or maybe by the device being unlocked). Internal AT modem commands that are delivered through the apps and services that are installed on the device, such as the dialer app, messaging app, or the kernel as it may relate to network access are not restricted by this selection as they provide the expected functionality of the device.

Application Note 36: The ability to grant/revoke permission to/from downloaded app or preinstalled app without system permission an app or process to have access to accessibility service, applies to the system software that has such capabilities. If the system software does not support this permission right, the requirement is not applicable.

8.3.6 Privacy (FPR)

To avoid tracking of the unique Device ID of the TOE, the TOE provides aliases of the Device ID for App Developers and ad networks. App Developers may be able to generate their own aliases on top of ones provided by the TOE itself (these are out of scope) or request the TSF to provide an unique alias for its use. The TOE may provide unique aliases for different purposes or a single global aliases as needed. The user can reset these aliases to prevent tracking to continue indefinitely (see FMT_SMF.1/Privacy).

FPR_PSE.1/Advertisers Pseudonymity

FPR_PSE.1.1/Advertisers The TSF shall ensure that [*ad networks*] are unable to ~~determine~~ **access** the ~~real user name~~ **Device ID** bound to [*the TOE (hardware platform)*] **according to the Permissions Policy**.

FPR_PSE.1.2/Advertisers The TSF shall be able to provide [*at least one unique*] alias**(**es**)** of the ~~real user name~~ **Device ID** to [*ad networks*].

FPR_PSE.1.3/Advertisers The TSF shall [determine an alias for a device ID] ~~and verify that it conforms to the [assignment: *alias metric*]~~.

FPR_PSE.1/APP_Dev Pseudonymity

FPR_PSE.1.1/APP_Dev The TSF shall ensure that [*App Developers*] are unable to ~~determine~~ **access** the ~~real user name~~ **Device ID** bound to [*the TOE (hardware platform)*] **according to the Permissions Policy**.

FPR_PSE.1.2/APP_Dev The TSF shall be able to provide [*at least one unique*] alias**(**es**)** of the ~~real user name~~ **Device ID** to [*each App Developer*].

FPR_PSE.1.3/APP_Dev The TSF shall [provide an alias for a device ID] ~~and verify that it conforms to the [assignment: *alias metric*]~~ **upon request by the App Developer**.

8.3.7 Protection of the TSF (FPT)

Protection of the various keys used to protect the TOE and the user data assets is critical. The different keys in the hierarchy will have different protections based on what they are being used for and how the TSF are implemented. There are three ways these keys may be protected, depending on how they are tied back to the hardware capabilities of the CMD. These are defined as:

- Physical features of the SoC: these are areas, such as write-once memory bits that may be used to permanently embed a key or key-related information into the hardware. Depending on the location of the area, they may be difficult or easy to access, as determined by the use of the information.
- Hardware-isolated component: this is defined as embedded Secure Elements (eSE), Secure Processing Units (SPU) or components with similar functionality that is independent from the Application Processor of the SoC.
- Hardware-protected component: this is defined as a Separate Execution Environments (SEE) or systems with similar functionality where the processing is handled separately from the main OS but is dependent on functionality provided by the Application Processor of the SoC for protection the separate environments by some means of hardware enforcement.

FPT_PHP.3 Resistance to physical attack

FPT_PHP.3.1 The TSF shall resist [*to:*

- *read or modify the DUK;*
- *read or modify [assignment: list of data and keys in the key hierarchies of the FCS_CKH_EXT.1 SFRs which are stored on the device];*

- *modify [assignment: any key(s), hashes of key(s), certificate(s) and/or other data] used to verify the integrity of the TSF in FPT_TST.1;*
- *modify [assignment: any key(s), hashes of key(s), certificate(s) and/or other data] used to verify the integrity and authenticity of updates to the TSF in FCS_COP.1/SigGen;*
- *read or modify the keys placed into the user keystore by apps on behalf of the user;*
- *read or modify [assignment: list of other data and/or keys]*];

to the **[**selection:

- *to physical features of the SoC;*
- *to a hardware-isolated component;*
- *to a hardware-protected component;*

*[*assignment: *other secure environment of the TSF*]

by responding automatically such that the SFRs are always enforced.

Application Note 37: This requirement is on physical attacks only; logical attacks are addressed by the ADV_ARC and AVA_VAN assurance requirements.

The phrase "responding automatically" means both active detection of attacks and passive resistance to attacks. Active detection of an attack and taking appropriate protective action when detected is similar to an alarm system detecting an attack (tamper responsive). Passive resistance to an attack can be by being very difficult to access, similar to a safe, which is very hard to open, and can even be hidden so hard to be located.

Guidance on types of physical attacks and mitigations thereof can be found in [i.3].

The Security Target Author can define alternative secure environments as necessary.

Each type of key or data resistance shall be tied to the appropriate selections of the component providing the resistance.

FPT_FLS.1 Failure with preservation of secure state

FPT_FLS.1.1 The TSF shall preserve a secure state when the following types of failures occur: [*failure of the Update_SSW operation in FDP_ACF.1/SSW_Update, integrity verification failure in FPT_TST.1*].

Application Note 38: A secure state can be the state before the update is executed or a state for recovery as defined in FPT_RCV.2 Automated recovery.

FPT_RCV.2 Automated recovery

FPT_RCV.2.1 When automated recovery from [*any integrity failure by FPT_TST.1 or failure of the Update_SSW operation by FDP_ACF.1/SSW_Update*] is not possible, the TSF shall enter a maintenance mode where the ability to return to a secure state is provided.

FPT_RCV.2.2 For [*detection of any integrity failure by FPT_TST.1 or failure of the Update_SSW operation by FDP_ACF.1/SSW_Update*], the TSF shall ensure the return of the TOE to a secure state using automated procedures.

Application Note 39: FPT_RCV.2.2 mandates that the TOE returns to a secure state using automated procedures. This state can be one where an integrity failure is corrected. This can be a malevolent persistent presence that is completely removed, or it can be a state where the malevolent persistent presence is not loaded, or otherwise not activated, or an automated correction of an integrity error that was preventing a successful boot. In the case where it is not possible to automatically remove the malevolent persistent presence or correct the integrity error, FPT_RCV.2.1 allows user to remove it manually, for example by a factory reset or download of an update.

FPT_TST.1 TSF testing

FPT_TST.1.1 The TSF shall run ~~a suite of self~~ **integrity verification** [during initial start-up] to demonstrate the correct operation of [*the bootloader, main OS kernel,* [selection: *SEE, [assignment: parts of TSF]*]: [selection: *a digital signature using an immutable hardware asymmetric key*, *an immutable hardware hash of an asymmetric key*, *an immutable hardware hash*, *a digital signature using a hardware-protected asymmetric key*].

FPT_TST.1.2 The TSF shall provide authorized users with the capability to verify the integrity [*no data*].

FPT_TST.1.3 The TSF shall provide authorized users with the capability to verify the integrity of [*none*].

Application Note 40: FPT_TST.1.1 allows the ST author to specify tests for verifying the loaded components have not been modified. The ST author can choose which mechanisms are to be tested and complete FPT_TST.1.1 accordingly.

An integrity test failure may detect general system failures, attack attempts or a malevolent persistent presence on the CMD.

8.3.8 Trusted Path/Channels (FTP)

A TOE supports many different communication channels, conforming to different standards, and within these standards, using different settings, resulting in different levels of security. While there may be additional channels, the three below are considered to be the most fundamental to a mobile device. These cover Bluetooth and WLAN wireless communications as well as software functions to ensure secure communications between applications/services on the device and servers hosted elsewhere.

This does not preclude the TOE providing communication channels based on these standards with less secure settings to communicate with devices that are legacy or have limited secure communication capabilities. As part of the vulnerability analysis the impact these lower settings can have on the overall security of the TOE will be assessed.

The TOE should provide the ability for downloaded apps to use some of the secure channel mechanisms for their communications. In this case, the "trusted IT product" that the app communicated with will be determined by the app itself.

FTP_PRO.1/BT Trusted channel protocol

FTP_PRO.1.1/BT The TSF shall implement [*Bluetooth® core specification*] acting as [*client and server*] in accordance with: [*Bluetooth® core specification [*selection: *v5.2 [*15*]*, *v5.3 [*26*]*, *v5.4 [*27*]*, *v6.0 [*28*]*, *v6.1 [*29*]*, *v6.2 [*30*]*, *v6.3 [*31*] [*assignment: *a version higher than v6.3]*].

FTP_PRO.1.2/BT The TSF shall enforce usage of the trusted channel for [*pairing between Bluetooth devices*] in accordance with: [*the Bluetooth® core specification listed in FTP_PRO.1.1/BT*].

FTP_PRO.1.3/BT The TSF shall permit [itself, its peer] to initiate communication via the trusted channel.

FTP_PRO.1.4/BT The TSF shall enforce the following rules for the trusted channel: [

- *require explicit user authorization before pairing;*
- *use secure simple pairing and secure connections for pairing;*
- *not allow more than one Bluetooth connection to the same Bluetooth device address.*

Application Note 41: The requirement for secure simple pairing does not preclude legacy compatibility or the ability to connect to devices which do not support secure simple pairing, only that secure simple pairing should be available and used by default if both devices support it.

FTP_PRO.1.5/BT The TSF shall enforce the following static protocol options: [*generate new ECDH public/private key pairs every [*selection: *24 hours*, *three failed authentication attempts from any Bluetooth device address*, *ten successful pairings from any Bluetooth device address*, *[assignment: other frequency and/or criteria for new key pair generation]]*].

FTP_PRO.1.6/BT The TSF shall negotiate one of the following protocol configurations with its peer: [*None specified*].

FTP_PRO.1/TLS Trusted channel protocol

FTP_PRO.1.1/TLS The TSF shall implement [*TLS*] acting as [*a client*] in accordance with: [*TLS v1.3 [*10*], [*selection: *TLS v1.2 [*6*], a version higher than TLS v1.3, no other version*].

FTP_PRO.1.2/TLS The TSF shall enforce usage of the trusted channel for [*communication with a trusted IT product*] in accordance with: [*the TLS specification listed in FTP_PRO.1.1/TLS*].

FTP_PRO.1.3/TLS The TSF shall permit [itself] to initiate communication via the trusted channel.

FTP_PRO.1.4/TLS The TSF shall enforce the following rules for the trusted channel: [

- *support HTTPS that conforms to IETF RFC 9110 [*34*];*
- *support X.509v3 certificates for mutual authentication;*
- *determine validity of the peer certificate by certificate path, expiration date and revocation status according to IETF RFC 5280 [7];*
- *notify the TSF and [*selection: *not establish the connection, request application authorization to establish the connection, no other action] if the peer certificate is deemed invalid*].

FTP_PRO.1.5/TLS The TSF shall enforce the following static protocol options: [*No NULL ciphers are allowed*].

FTP_PRO.1.6/TLS The TSF shall negotiate one of the following protocol configurations with its peer: [*None specified*].

FTP_PRO.1/WLAN Trusted channel protocol

FTP_PRO.1.1/WLAN The TSF shall implement [*WLAN*] acting as [*a client*] in accordance with: [selection: *IEEE 802.11-2020 [*32*], IEEE 802.11-2024 [*33*], a version higher than IEEE 802.11-2024*].

FTP_PRO.1.2/WLAN The TSF shall enforce usage of the trusted channel for [*a client*] in accordance with: [*the IEEE 802.11 specification listed in FTP_PRO.1.1/WLAN*].

FTP_PRO.1.3/WLAN The TSF shall permit [itself] to initiate communication via the trusted channel.

FTP_PRO.1.4/WLAN The TSF shall enforce the following rules for the trusted channel: [

- *randomly generate a new MAC address each time it connects to a different access point;*
- *supports Wi-Fi Protected Access 3 (WPA3)*].

FTP_PRO.1.5/WLAN The TSF shall enforce the following static protocol options: [*None specified*].

FTP_PRO.1.6/WLAN The TSF shall negotiate one of the following protocol configurations with its peer: [*None specified*].

8.4 Security assurance requirements

8.4.1 Introduction

The security assurance requirements consist of EAL2 augmented with ALC_CMS.3, ADV_PDM_EXT.1, ALC_DVS_EXT.0 and ALC_FLR.3 [21] as defined here.

The security assurance requirements follow the same conventions as the security functional requirements for changes to the requirement from the Security Assurance Requirements catalog [21].

8.4.2 Augmented security assurance requirements

ADV_PDM_EXT.1: Processed Data Minimisation

ADV_PDM_EXT.1.1D The developer shall design and implement the TOE so that it only processes user and usage data that is necessary and adequate in relation with the intended use of the TOE.

ADV_PDM_EXT.1.2D The developer shall provide a rationale for data minimisation of the TOE.

ADV_PDM_EXT.1.1C The rationale for data minimisation shall identify all user and usage data that is processed by the TOE.

ADV_PDM_EXT.1.2C The rationale for data minimisation shall demonstrate that all user and usage data processed by the TOE is necessary and adequate in relation with the intended purpose of the TOE.

ADV_PDM_EXT.1.1E The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

ALC_DVS_EXT.0 Documentation of security measures for device identifiers

ALC_DVS_EXT.0.1D The developer shall produce and provide development security documentation on the generation, protection and use of signing keys.

ALC_DVS_EXT.0.2D The developer shall produce and provide development security documentation on the acquisition or generation of device unique identifiers.

ALC_DVS_EXT.0.1C The development security documentation shall describe all the physical, procedural, personnel, and other security measures that are necessary to protect the confidentiality and integrity of the keys used to sign the publicly released system software and its updates and to ensure the use of the proper keys in the build process;

ALC_DVS_EXT.0.2C The development security documentation shall describe the procedures for selecting the proper signing keys used for a device and to ensure the use of the proper keys in the build process.

ALC_DVS_EXT.0.3C The development security documentation shall describe all the physical, procedural, personnel, and other security measures that are necessary to protect the confidentiality and integrity of the unique, non-modifiable identifiers (such as IMEI, attestation keys or Device Unique Keys) are properly created and provisioned for each device.

ALC_DVS_EXT.0.1E The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

ALC_DVS_EXT.0.2E The evaluator shall review the provided evidence that the security measures are being applied.

ALC_FLR.3 Systematic flaw remediation (refined)

ALC_FLR.3.1D The developer shall document and provide flaw remediation procedures addressed to TOE manufacturers.

ALC_FLR.3.2D The developer shall establish a procedure for accepting and acting upon all reports of security flaws and requests for corrections to those flaws.

ALC_FLR.3.3D The developer shall provide flaw remediation guidance addressed to TOE users.

ALC_FLR.3.4D The developer shall provide public guidance related to the frequency, length of time and type of updates that will be released to support the TOE.

ALC_FLR.3.5D The developer shall provide a public vulnerability disclosure program to provide security bulletins about the flaws that have been remediated.

ALC_FLR.3.6D The developer shall establish procedures for ensuring that no known security vulnerabilities rated as High and Critical (e.g. those classified in public databases) are included in the TOE at public release.

ALC_FLR.3.1C The flaw remediation procedures documentation shall describe the procedures used to track all reported security flaws in each release of the TOE.

ALC_FLR.3.2C The flaw remediation procedures shall require that a description of the nature and effect of each security flaw be provided, as well as the status of finding a correction to that flaw.

ALC_FLR.3.3C The flaw remediation procedures shall require that corrective actions be identified for each of the security flaws.

ALC_FLR.3.4C The flaw remediation procedures documentation shall describe the methods used to provide flaw information, corrections and guidance on corrective actions to TOE users.

ALC_FLR.3.5C The flaw remediation procedures shall describe a means by which the developer receives from TOE users reports and enquiries of suspected security flaws in the TOE.

ALC_FLR.3.6C The flaw remediation procedures shall include a procedure requiring timely response and the automatic distribution of security flaw reports and the associated corrections to registered users who might be affected by the security flaw.

ALC_FLR.3.7C The procedures for processing reported security flaws shall ensure that any reported flaws are remediated and the remediation procedures issued to TOE users.

ALC_FLR.3.8C The procedures for processing reported security flaws shall provide safeguards that any corrections to these security flaws do not introduce any new flaws.

ALC_FLR.3.9C The flaw remediation guidance shall describe a means by which TOE users report to the developer any suspected security flaws in the TOE.

ALC_FLR.3.10C The flaw remediation guidance shall describe a means by which TOE users may register with the developer, to be eligible to receive security flaw reports and corrections.

ALC_FLR.3.11C The flaw remediation guidance shall identify the specific points of contact for all reports and enquiries about security issues involving the TOE.

ALC_FLR.3.12C The flaw remediation procedures documentation shall define the planned minimum length of time after release of the TOE that these methods will be used to maintain the TOE.

ALC_FLR.3.13C The flaw remediation procedures documentation shall define the types of updates (such as security/maintenance or operating system) and the frequency of these updates being provided for the TOE.

ALC_FLR.3.14C The flaw remediation procedures documentation shall describe the process for publicly releasing security flaw remediation information, including the location(s) where this will be publicly available.

ALC_FLR.3.15C The flaw remediation procedures documentation shall describe the process for verifying known security flaws are not propagated into a new (not yet released) TOE.

ALC_FLR.3.1E The evaluator shall confirm that the information provided meets all requirements for content and presentation of evidence.

8.4.3 Independent testing considerations (ATE_IND.1)

The TOE can have multiple wireless connectivity interfaces, including WLAN (always available) and cellular mobile communication. All available network interface (e.g. the cellular mobile communication) can be used on devices and by services for connectivity subject to availability. When testing for network-based security functions, it should be considered if the TSF might change its behaviour based upon the presented network (e.g. WLAN vs cellular mobile communication).

EXAMPLE: It is expected that TLS testing over the WLAN interface is sufficient and test results should cover the cellular mobile communication interface, but this needs to be confirmed by the evaluator

8.4.4 Vulnerability assessment considerations (AVA_VAN.2)

The TOE, as a CMD, contains many third party components on which security services are provided. Within the scope of the security requirements for the CMD, some of these components, explicitly radio hardware, are expected to provide security according to specifications that are not included within the evaluation boundary. In this case, the radios are expected to meet the specifications which are specified within the appropriate SFR, including the security requirements in those specifications.

Attacks on the radio hardware are considered, in general, to be above AVA_VAN.2, so while public vulnerabilities should be patched, it is not expected that actual radio attacks will be in scope as part of the vulnerability assessment.

8.5 Security requirements rationale

8.5.1 Rationale for choosing the SARs

EAL2 is chosen as it provides a good balance between effort expected from the developer and assurance gained.

EAL2 provides assurance by a full security target and an analysis of the SFRs in that ST, using a functional and interface specification, guidance documentation and a basic description of the architecture of the TOE, to understand the security behaviour.

NOTE: Requirements for functional and interface specification, guidance documentation and description of the architecture of the TOE are defined in [21].

The analysis is supported by independent testing of the TSF, evidence of developer testing based on the functional specification, selective independent confirmation of the developer test results, and a vulnerability analysis (based upon the functional specification, TOE design, security architecture description and guidance evidence provided) demonstrating resistance to penetration attackers with a basic attack potential.

EAL2 also provides assurance through use of a configuration management system and evidence of secure delivery procedures.

EAL2 is augmented with ALC_DVS_EXT.0 (extended) because a major part of securing CMDs is to ensure that the TOE software that will be deployed to the devices is authorized by the developer. Proper key management includes ensuring keys are generated and stored properly as well as ensuring that the proper keys are used when production devices are produced. ALC_DVS_EXT.0 (extended) requires the TOE manufacturer to:

- ensure keys are properly generated and stored;
- ensure proper access (physical and logical) to signing keys and how they are used in the build process;
- ensure proper access (physical and logical) to the generation of device unique identifiers.

EAL2 is augmented by ALC_FLR.3 (refined) because CMDs are complex devices that are often subject to many hacking attempts and security investigations, that can result in the discovery of security flaws. ALC_FLR.3 (refined) provides assurance that the TOE will be maintained and supported in the future, and require the TOE manufacturer to have procedures to:

- accept suspected security flaws in the TOE from third parties and from their own internal processes; and
- process these suspected flaws to determine whether they are actual security flaws; and
- correct the actual security flaws; and
- distribute these corrections to TOEs in the field automatically in a timely fashion.

An example is that the present document requires resistance against physical attacks through FPT_PHP.3 in such a way that it allows different implementations and is therefore fairly abstract. If a developer uses a certified secure element (where the implementation is known), it is likely that the requirements in the ST of that secure element are much more detailed and therefore different, but still be more than sufficient to meet the FPT_PHP.3 requirement of the present document. If strict or exact conformance was specified, the secure element would have to be recertified against a ST containing a suitably completed copy of the FPT_PHP.3 in the present document, which would cause a lot of unnecessary work.

8.5.2 The SFRs meet all the security objectives for the TOE

Security Objective	Rationale
O.ACCESS_CONTROL	This objective is achieved by: • FDP_ACC.2/Permissions, FDP_ACF.1/Permissions, specifying that user permission is needed and FMT_SMF.1/Permissions, FMT_MSA.1/Permissions allowing users to provide and revoke such permission. FMT_MSA.3/Permissions that the default permission is no access until granted by the user. • FMT_SMF.1/UserControls that the user can control additional privileges around functions which can allow access to user data assets. • FPR_PSE.1 allowing App Developers and Advertisers the ability to track TOEs, but denying their Apps access to a permanent ID of the TOE, and providing an alias instead. FMT_SMF.1/Privacy allows users to reset the alias.
O.AUTHENTICATE_PEER_DEVICE	This objective is achieved by FIA_UAU.5/Peer specifying how trusted peer devices are authenticated and what they can do after authentication.
O.AUTHENTICATE_USER	This objective is achieved by: • FMT_SMF.1/Authentication specifying that users can register their authentication data and change this later. • FIA_UAU.1 specifying that each user can only perform limited actions before being authenticated and is authenticated to gain full access. • FIA_UID.1 specifying that each user can only perform limited actions before being identified (via authentication) to gain full access. • FIA_UAU.6 listing the conditions under which a user is to be re-authenticated. • FIA_UAU.5/Local listing the multiple authentication mechanism a TOE has, and the rules for using these. • FIA_SOS.1 listing the minimum quality requirements for authentication (password/PIN length). • FIA_AFL.1 specifying what happens when authentication fails repeatedly for each mechanism. FIA_UAU.7 specifying that passwords and PINs are not displayed on the screen when entering them, preventing shoulder surfing.
O.AUTHENTICATED_UPDATES	These objectives are achieved by: • FAP_LFC_EXT.1 by specifying how the preloaded applications will be updated. • FDP_ACC.1/APP_Update, FDP_ACF.1/APP_Update and FDP_ACC.2/SSW_Update and FDP_ACF.1/SSW_Update specify the policies for updating. • FDP_UPF_EXT.1/APP_Update and FDP_UPF_EXT.1/SSW_Update specify the notification frequency for updating. • FCS_COP.1/SigGen specifying the cryptographic mechanism for checking the validity of an update. • FMT_SMF.1/APP_Update and FMT_SMF.1/SSW_Update, specifying that user can initiate an update. • FPT_FLS.1, specifying that failure to correctly update will not lead to an insecure state.
O.CRITICAL_STORAGE	This objective is achieved by FPT_PHP.3 and FDP_SDI.1 which directly implements the objective.
O.CRYPTOGRAPHY	This objective is achieved by the requirements FCS_CKM.1/Asymmetric, FCS_CKM.1/Symmetric, FCS_COP.1/SigGen, FCS_COP.1/KeyEst, FCS_COP.1/Symmetric, FCS_CKM.5, FCS_COP.1/Hash and FCS_COP.1/KeyedHash by ensuring properly vetted cryptographic algorithms are used.

Security Objective	Rationale
O.DATA_CLASSIFICATION **O.PROTECT_ASSETS_AT_REST**	These objectives are achieved by: • FDP_ACC.1/UserDataAsset and FDP_ACF.1/UserDataAsset showing the three classes of user data assets, and when each class can be decrypted. • FCS_COP.1/Symmetric, specifying how they are encrypted and decrypted. • FSC_CKH_EXT.1/Low, FCS_CKH_EXT.1/MediumHigh describing how the cryptographic keys are derived and protected.
O.OLD_APP_WARNING	This objective is achieved by FAP_LFC_EXT.2 which specifies how users are warned when preloaded applications contained in the system software have their updates removed.
O.PROTECT_COMMS	This objective is achieved by FTP_PRO.1/BT, FTP_ITC_EXT.1/TLS and FTP_ITC_EXT.1/WLAN which set up secure channels with authentication and protection from modification and disclosure.
O.RANDOMS	• This objective is achieved by FCS_RBG.1 and FCS_RBG.3 defining a random generator, whose output meets stringent international standards.
O.SECURE_BOOT	These objectives are achieved by FPT_TST.1, testing the integrity of the TSF, and FPT_RCV.2 specifying the actions to be undertaken (either automatic or by the user) when a malevolent presence is found.
O.SECURE_WIPE	• This objective is achieved by FCS_CKM.6 specifying that keys from the key hierarchy for each class of data can be deleted on request of the user, making the data unreadable.
O.SELF_PROTECTION	This objective is achieved by: • FPT_TST.1 specifying that the TSF runs self-testing and integrity verification of the TSF or part of the TSF to protect the TSF to be tampered; and • FPT_PHP.3 to prevent modification of key(s), hashes of key(s), certificate(s) and/or other data used to verify the integrity of the TSF.
O.SEPARATION	This objective is achieved by: • FDP_ACC.2/Permissions and FDP_ACF.1/Permissions defining security attribute based access control for apps; and • FMT_SMF.1/Permissions specifying management functions for apps.

8.5.3 Dependency analysis

FAP_LFC_EXT.1	**-**	
FAP_LFC_EXT.2	-	
FCS_CKM.1/Asymmetric	[FCS_CKM.2 or FCS_COP.1] FCS_CKM.6	Fulfilled by FCS_CKM.2, to establish key hierarchy. Fulfilled by FCS_CKM.6.
FCS_CKM.1/Symmetric	[FCS_CKM.2 or FCS_COP.1] FCS_CKM.6	Fulfilled by FCS_COP.1/Symmetric, to encrypt and decrypt data. Fulfilled by FCS_CKM.6.
FCS_COP.1/SigGen	[FDP_ITC.1 or FDP_ITC.2 or FCS_CKM.1] FCS_CKM.6	Fulfilled by FCS_CKM.1/Asymmetric. Fulfilled by FCS_CKM.6 for most cases, though some keys (such as the system software update key) are never destroyed as they are stored in write-once memory.
FCS_COP.1/AKeyGen	[FDP_ITC.1 or FDP_ITC.2 or FCS_CKM.1] FCS_CKM.6	Fulfilled by FCS_CKM.1/Asymmetric. Fulfilled by FCS_CKM.6.
FCS_COP.1/KeyEst	[FDP_ITC.1 or FDP_ITC.2 or FCS_CKM.1] FCS_CKM.6	Fulfilled by FCS_CKM.1/Asymmetric. Fulfilled by FCS_CKM.6.

FCS_COP.1/Symmetric	[FDP_ITC.1 or FDP_ITC.2 or FCS_CKM.1] FCS_CKM.6	Fulfilled by FCS_CKM.1/Symmetric. Fulfilled by FCS_CKM.6.
FCS_CKM.5	[FCS_CKM.2 or FCS_COP.1] FCS_CKM.6	Fulfilled by FCS_COP.1. Fulfilled by FCS_CKM.6.
FCS_COP.1/Hash	[FDP_ITC.1 or FDP_ITC.2 or FCS_CKM.1] FCS_CKM.6	Not fulfilled. There is no key involved for this operation.
FCS_COP.1/KeyedHash	[FDP_ITC.1 or FDP_ITC.2 or FCS_CKM.1] FCS_CKM.6	Fulfilled by FCS_CKM.1/Symmetric. Fulfilled by FCS_CKM.6.
FCS_CKH_EXT.1/Low	[FCS_CKM.1 or FCS_COP.1] FCS_CKM.6	Fulfilled by FCS_CKM.1/Symmetric, FCS_COP.1/Symmetric. Fulfilled by FCS_CKM.6.
FCS_CKH_EXT.1/MediumHigh	[FCS_CKM.1 or FCS_COP.1] FCS_CKM.6	Fulfilled by FCS_CKM.1/Symmetric, FCS_CKM.1/Asymmetric, FCS_COP.1/Symmetric, FCS_COP.1/Asymmetric. Fulfilled by FCS_CKM.6.
FCS_CKM.6	[FDP_ITC.1 or FDP_ITC.2 or FCS_CKM.1]	Fulfilled by FCS_CKM.1/Asymmetric and FCS_CKM.1/Symmetric.
FCS_RBG.1	[FCS_RBG.2 or FCS_RBG.3] FPT_FLS.1 FPT_TST.1	Fulfilled by FCS_RBG.3. Fulfilled by FPT_FLS.1. Fulfilled by FPT_TST.1.
FCS_RBG.3	FCS_RBG.1	Fulfilled by FCS_RBG.1.
FDP_ACC.1/APP_Update	FDP_ACF.1	Fulfilled by FDP_ACF.1/APP_Update.
FDP_ACF.1/APP_Update	FDP_ACC.1 FMT_MSA.3	Fulfilled by FDP_ACC.1/APP_Update. Not necessary, there are no security attributes that can be managed by the user.
FDP_UPF_EXT.1/APP_Update	-	
FDP_ACC.2/SSW_Update	FDP_ACF.1	Fulfilled by FDP_ACF.1/SSW_Update.
FDP_ACF.1/SSW_Update	FDP_ACC.1 FMT_MSA.3	Fulfilled by FDP_ACC.2/SSW_Update. Not necessary, there are no security attributes that can be managed by the user.
FDP_UPF_EXT.1/SSW_Update	-	
FDP_ACC.2/Permissions	FDP_ACF.1	Fulfilled by FDP_ACF.1/Permissions.
FDP_ACF.1/Permissions	FDP_ACC.1 FMT_MSA.3	Fulfilled by FDP_ACC.2/Permissions. Fulfilled by FMT_MSA.3/Permissions.
FDP_ACC.1/UserDataAsset	FDP_ACF.1	Fulfilled by FDP_ACF.1/UserDataAsset.
FDP_ACF.1/UserDataAsset	FDP_ACC.1 FMT_MSA.3	Fulfilled by FDP_ACC.1/UserDataAsset. Not necessary, as the security attributes Low, Medium and High do not change.
FDP_SDI.1	-	
FIA_UAU.1	FIA_UID.1	Fulfilled by FIA_UID.1.
FIA_UID.1	-	
FIA_UAU.5/Local	-	

FIA_UAU.5/Peer	-	
FIA_UAU.6	-	
FIA_UAU.7	FIA_UAU.1	Fulfilled by FIA_UAU.1.
FIA_SOS.1	-	
FIA_AFL.1/	FIA_UAU.1	Fulfilled by FIA_UAU.1.
FMT_MSA.1/Permissions	[FDP_ACC.1 or FDP_IFC.1] FMT_SMR.1 FMT_SMF.1	Fulfilled by FDP_ACC.2/Permissions (hierarchical to FDP_ACC.1). Only one user is supported. Fulfilled by FMT_SMF.1/Permissions.
FMT_MSA.3/Permissions	FMT_MSA.1 FMT_SMR.1	Fulfilled by FMT_MSA.1/Permissions. Only one user is supported.
FMT_SMF.1/Authentication	-	
FMT_SMF.1/Permissions	-	
FMT_SMF.1/UserControls	-	
FMT_SMF.1/Privacy	-	
FMT_SMF.1/APP_Update	-	
FMT_SMF.1/SSW_Update	-	
FPR_PSE.1	-	
FPT_PHP.3	-	
FPT_FLS.1	-	
FPT_TST.1	-	
FPT_RCV.2	AGD_OPE.1	Fulfilled by EAL2.
FTP_ITC.1	-	
FTP_PRO.1/BT	FTP_PRO.2 FTP_PRO.3	Not fulfilled. The requirement is being completed by referencing external standards for Bluetooth which specify how channel establishment and channel data protection are handled.
FTP_PRO.1/TLS	FTP_PRO.2 FTP_PRO.3	Not fulfilled. The requirement is being completed by referencing external standards for TLS connectivity which specify how channel establishment and channel data protection are handled.
FTP_PRO.1/WLAN	FTP_PRO.2 FTP_PRO.3	Not fulfilled. The requirement is being completed by referencing external standards for WLAN which specify how channel establishment and channel data protection are handled.
EAL2	Many	All dependencies in an EAL are met.
ADV_PDM_EXT.1	-	-
ALC_CMS.3	-	-
ALC_DVS_EXT.0	-	-
ALC_FLR.3	-	-

Annex A (informative): Other related specifications

A.1 ETSI EN 303 645

Table A.1 shows the correspondence between clause 5 (Cyber Security Requirements) and clause 6 (Data Protection Provisions) of ETSI EN 303 645 [i.1] and the present document. If a device meets SFRs of the present document, it can also meet corresponding provisions in ETSI EN 303 645 [i.1]. Note that the present document is defined as a PP for consumer mobile devices, and products claiming conformance to the PP will be evaluated by an accredited security test lab for CC evaluation, while ETSI EN 303 645 [i.1] is defined as baseline security requirements for consumer IoT devices, which can be used for conformance testing. These two documents are defined for different purpose of use, therefore table A.1 indicates the approximate relation, and details can differ.

Table A.1

ETSI EN 303 645 [i.1]	The present document	Comments
Provision 5.0-1 *A justification shall be recorded for each recommendation in the present document that is considered to be not applicable for or not fulfilled by the consumer IoT device.*		
Provision 5.1-1 *Where passwords are used to authenticate users against the device or for machine-to-machine authentication, and in any state other than the factory default, all consumer IoT device passwords shall be unique per device or defined by the user*	FIA_SOS.1 and OE.PASSWORD_PIN_PATTERN	Passwords are user generated. ETSI TS 103 732-2 [i.16] has requirements for biometric authentication that are relevant for device authentication since they could be used along with passwords.
Provision 5.1-2 *Where pre-installed unique per device passwords are used to authenticate users against the device or for machine-to-machine authentication, these shall be generated with a mechanism that reduces the risk of automated attacks against a class or type of consumer IoT device.*	-	Not relevant, as passwords are not pre-installed.
Provision 5.1-2A *Passwords should not be used for machine-to-machine authentication.*	FIA_UAU.5/Peer	This provides multiple mechanisms for establishing connectivity between the device and remote services that enable easy connectivity without the need for simple passwords input by the user.
Provision 5.1-3 *Authentication mechanisms used to authenticate users against the consumer IoT device or used for machine-to-machine authentication shall use best practice cryptography, appropriate to the properties of the technology, operating environment, risk and usage.*	Cryptography requirements specify algorithms are compliant with the ISO/IEC 18033-1 [17] for new algorithms	
Provision 5.1-4 *Where a user can authenticate against a consumer IoT device, the consumer IoT device shall provide to the user or an administrator a simple mechanism to change the authentication value used.*	FMT_SMF.1/Authentication	

ETSI EN 303 645 [i.1]	The present document	Comments
Provision 5.1-5 *The consumer IoT device shall have a mechanism available which makes successful brute force attacks on authentication mechanisms via network interfaces impracticable unless the device has a resource constraint determined by the use case that prevents the implementation.*	FIA_AFL.1 provides protection for local brute force attacks	User authenticates locally to the CMD and not via network interfaces. ETSI TS 103 732-2 [i.16] has requirements for biometric authentication that are relevant for device authentication since they could be used along with passwords.
Provision 5.2-1 *The manufacturer shall make a vulnerability disclosure policy publicly available. This policy shall include, at a minimum:* • *contact information for the reporting of issues; and* • *timelines for:* *1) initial acknowledgement of receipt of a vulnerability report; and* *2) timelines for when the person who reported the issue will receive status updates until the resolution of the reported issues.*	ALC_FLR.3	
Provision 5.2-2 *Disclosed vulnerabilities should be acted on in a timely manner.*	ALC_FLR.3	
Provision 5.2-3 *Manufacturers should continually monitor for, identify and rectify security vulnerabilities within consumer IoT products they sell, produce, have produced and associated services they operate during the defined support period.*	ALC_CMC.2 ALC_CMC.3 ALC_FLR.3	
Provision 5.3-1 *All software components in consumer IoT devices that are not immutable due to security reasons should be securely updateable.*	FDP_ACC.1/APP_Update FDP_ACF.1/APP_Update FDP_ACC.1/SSW_Update FDP_ACF.1/SSW_Update	This only applies to the OS and the OEM apps. All other apps are outside the scope of this requirement
Provision 5.3-2 *The consumer IoT device shall have a secure update mechanism unless the device has a resource constraint determined by the use case that prevents the implementation.*	FDP_ACC.1/APP_Update FDP_ACF.1/APP_Update FDP_ACC.1/SSW_Update FDP_ACF.1/SSW_Update	
Provision 5.3-3 *An update shall be simple for the user to apply.*	FMT_SMF.1/APP_Update FMT_SMF.1/SSW_Update	
Provision 5.3-4 *Void*		
Provision 5.3-4A *One secure update mechanism should be configurable to be automated.*	FDP_ACC.1/APP_Update FDP_ACF.1/APP_Update FDP_UPF_EXT.1/APP_Update FDP_ACC.1/SSW_Update FDP_ACF.1/SSW_Update FDP_UPF_EXT.1/SSW_Update	CMD system software usually only updates after explicit user permission, though app updates may be automatic
Provision 5.3-4B *During initialization the consumer IoT device should activate an automatic secure update mechanism after user's consent.*	FDP_ACC.1/APP_Update FDP_ACF.1/APP_Update FDP_UPF_EXT.1/APP_Update FDP_ACC.1/SSW_Update FDP_ACF.1/SSW_Update FDP_UPF_EXT.1/SSW_Update	CMD system software usually only updates after explicit user permission, though app updates may be automatic
Provision 5.3-5 *The consumer IoT device or an associated service should check after initialization, whether security updates are available.*	FDP_UPF_EXT.1/APP_Update FDP_UPF_EXT.1/SSW_Update	
Provision 5.3-6 *Void*		

ETSI EN 303 645 [i.1]	The present document	Comments
Provision 5.3-6A *If the consumer IoT device supports automated updates, the user should be able to enable and disable the automatic update mechanism and postpone the installation of updates provided via an automatic update mechanism.*	FMT_SMF.1/APP_Update FDP_UPF_EXT.1/APP_Update FMT_SMF.1/SSW_Update FDP_UPF_EXT.1/SSW_Update	This only allows the user to determine to initiate an update, not to disable it
Provision 5.3-6B *If the consumer IoT device supports update notifications, the user should be able to enable and disable the update notifications.*	FMT_SMF.1/APP_Update FDP_UPF_EXT.1/APP_Update FMT_SMF.1/SSW_Update FDP_UPF_EXT.1/SSW_Update	The requirement is about receiving notifications. Given the update notifications are self-contained on the device, further management is possible, but the focus of the CMD requirements are to ensure security through regular updates. Security is maintained through update notifications, and potentially reduced when eliminated
Provision 5.3-7 *The consumer IoT device shall use best practice cryptography to facilitate secure update mechanisms.*	FCS_CKM.1/Asymmetric FCS_COP.1/SigGen ALC_DVS_EXT.0	
Provision 5.3-8 *Security updates shall be timely.*	ALC_FLR.3	
Provision 5.3-9 *The consumer IoT device should verify the authenticity and integrity of software updates.*	FDP_ACF.1/SSW_Update	
Provision 5.3-10 *Void.*		
Provision 5.3-11 *The user should be informed in a recognizable and apparent manner that a security update is required together with information on the risks mitigated by that update.*	FDP_UPF_EXT.1/APP_Update FDP_UPF_EXT.1/SSW_Update	This does not include informing the user of the risks mitigated by the update
Provision 5.3-12 *The user should be notified when the application of a software update will disrupt the basic functioning of the consumer IoT device.*	-	Not a security requirement
Provision 5.3-13 *The manufacturer shall publish, in an accessible way that is clear and transparent to the user, the defined support period.*	ALC_FLR.3 (refined)	
Provision 5.3-14 *For consumer IoT devices that cannot have their software updated, the rationale for the absence of software updates, the period and method of hardware replacement support and a defined support period should be published by the manufacturer in an accessible way that is clear and transparent to the user.*	-	CMDs can have always software updates.
Provision 5.3-15 *Void*	-	
Provision 5.3-*15A* *For devices that cannot have their software updated, the consumer IoT device should be isolable*		CMDs can have always software updates.
Provision 5.3-15B *For devices that cannot have their software updated, the consumer IoT device hardware should be replaceable.*		CMDs can have always software updates.
Provision 5.3-16 *The model designation of the consumer IoT device shall be clearly recognizable, either by labelling on the consumer IoT device or via a user interface.*	ALC_CMC.2 ALC_CMC.3	

ETSI EN 303 645 [i.1]	The present document	Comments
Provision 5.4-1 *Sensitive security parameters in persistent storage shall be stored securely by the consumer IoT device.*	FCS_CKH_EXT.1/Low FCS_CKH_EXT.1/MediumHigh FPT_PHP.3	
Provision 5.4-2 *Where a hard-coded unique per device identity is used in a consumer IoT device for security purposes, it shall be implemented in such a way that it resists tampering by means such as physical, electrical or software.*	FPT_PHP.3	
Provision 5.4-3 *Hard-coded critical security parameters in consumer IoT device software source code shall not be used.*	-	Source code inspection is outside EAL2. ETSI TS 103 732-4 [i.17] includes requirements on preloaded apps for basic security parameters not being hard-coded in the FAP_RSK.* requirements.
Provision 5.4-4 *Any critical security parameters used for integrity and authenticity checks of software updates and for protection of communication with associated services in consumer IoT device software shall be unique per device and shall be produced with a mechanism that reduces the risk of automated attacks against classes of consumer IoT devices.*	FCS_CKM.1/Asymmetric FCS_COP.1/SigGen ALC_DVS_EXT.0	
Provision 5.5-1 *The consumer IoT device shall use best practice cryptography to communicate securely.*	Cryptography requirements specify algorithms are compliant with the ISO/IEC 18033-1 [17] for new algorithms	
Provision 5.5-2 *The consumer IoT device should use reviewed or evaluated implementations to deliver network and security functionalities, particularly in the field of cryptography.*	Cryptography requirements specify algorithms are compliant with the ISO/IEC 18033-1 [17] for new algorithms	
Provision 5.5-3 *Cryptographic algorithms and primitives should be replaceable.*	FDP_ACC.1/SSW_Update FDP_ACF.1/SSW_Update	Some low-level capabilities cannot be changed (for example the signature checks for the system software update), but main OS functionality can be updated.
Provision 5.5-4 *Access to consumer IoT device functionality via a network interface in the initialized state should only be possible after authentication on that interface.*	FIA_UAU.5/Peer FTP_PRO.1/BT FTP_PRO.1/TLS FTP_PRO.1/WLAN	
Provision 5.5-5 C*onsumer IoT device functionality that allows security-relevant changes in configuration via a network interface shall only be accessible after authentication. The exception is for network service protocols that are relied upon by the device and where the manufacturer cannot guarantee what configuration will be required for the device to operate.*	FIA_UAU.5/Peer FTP_PRO.1/BT FTP_PRO.1/TLS FTP_PRO.1/WLAN	
Provision 5.5-6 *Critical security parameters should be encrypted in transit, with such encryption appropriate to the properties of the technology, risk and usage.*	FTP_PRO.1/BT FTP_PRO.1/TLS FTP_PRO.1/WLAN	

ETSI EN 303 645 [i.1]	The present document	Comments
Provision 5.5-7 *The consumer IoT device shall protect the confidentiality of critical security parameters that are communicated via remotely accessible network interfaces.*	FTP_PRO.1/BT FTP_PRO.1/TLS FTP_PRO.1/WLAN	
Provision 5.5-8 *The manufacturer shall follow secure management processes for critical security parameters that relate to the consumer IoT device and for the entire lifecycle of the critical security parameters.*	ALC_DVS_EXT.0	
Provision 5.6-1 *All unused network interfaces and all unused logical interfaces that are accessible through a network interface shall be disabled.*	AVA_VAN.2 (see detailed explanation after the table)	
Provision 5.6-2 *In the initialized state, the network interfaces of the consumer IoT device shall minimize the unauthenticated disclosure of security-relevant information.*	AVA_VAN.2 (see detailed explanation after the table)	
Provision 5.6-3 Consumer IoT *device hardware should not unnecessarily expose physical interfaces to attack.*	AVA_VAN.2 (see detailed explanation after the table)	
Provision 5.6-4 *Void.*		
Provision 5.6-4A *Debug interfaces shall be disabled or protected via a best practice authentication or access control mechanism*	AVA_VAN.2 (see detailed explanation after the table)	
Provision 5.6-4B *Debug interfaces that are physical ports should be physically protected by the device.*	AVA_VAN.2 (see detailed explanation after the table)	
Provision 5.6-5 *The manufacturer should only enable software services that are used or required for the intended use or operation of the consumer IoT device.*	AVA_VAN.2 (see detailed explanation after the table)	
Provision 5.6-6 *Code should be minimized to the functionality necessary for the consumer IoT device to operate.*	ADV_ARC.1 ALC_CMC.2 ALC_CMC.3	While source code inspection is outside EAL2, the product architecture defines what is or is not necessary for the product. Similarly, having all code in a CM system ensures that what is included is necessary for the CMD.
Provision 5.6-7 *Software should run with least necessary privileges, taking account of both security and functionality.*	FDP_ACC.2/Permissions FDP_ACF.1/Permissions	
Provision 5.6-8 *The consumer IoT device should include a hardware-level access control mechanism for memory.*	ADV_ARC.1	
Provision 5.6-9 *The manufacturer should follow secure development processes for software deployed on the consumer IoT device.*	EAL2	
Provision 5.7-1 *The consumer IoT device should verify its software using secure boot mechanisms.*	FPT_TST.1	ETSI TS 103 732-5 [i.18] includes additional requirements around secure boot and root of trust.
Provision 5.7-2 *If an unauthorized change is detected to the software, the consumer IoT device should alert the user and/or administrator to the issue and should not connect to wider networks than those necessary to perform the alerting function.*	FPT_TST.1 FPT_RCV.2	

ETSI EN 303 645 [i.1]	The present document	Comments
Provision 5.8-1 *The confidentiality of personal data transiting between the consumer IoT device andassociated services, should be protected, with best practice cryptography.*	FTP_PRO.1/BT FTP_PRO.1/TLS FTP_PRO.1/WLAN	
Provision 5.8-2 *The confidentiality of sensitive personal data communicated between the consumer IoT device and associated services shall be protected, with best practice cryptography appropriate to the properties of the technology, operating environment, risk and usage.*	FTP_PRO.1/BT FTP_PRO.1/TLS FTP_PRO.1/WLAN	
Provision 5.8-3 *All external sensing capabilities of the consumer IoT device shall be documented in an accessible way that is clear and transparent for the user.*	AGD_OPE.1	
Provision 5.9-1 *Resilience should be built in to consumer IoT products, taking into account the possibility of outages of data networks and power.*	FTP_PRO.1/TLS FTP_PRO.1/WLAN AVA_VAN.2 (see detailed explanation after the table)	The protocols for network access are chosen for resilience and expected to meet industry standards.
Provision 5.9-2 *Consumer IoT devices should remain operating and locally functional in the case of a loss of network access and should recover cleanly in the case of restoration of a loss of power.*	FTP_PRO.1/TLS FTP_PRO.1/WLAN AVA_VAN.2 (see detailed explanation after the table)	The protocols for network access are chosen for resilience and expected to meet industry standards.
Provision 5.9-3 *The consumer IoT device should connect to networks in an expected, operational and stable state and in an orderly fashion, taking the capability of the infrastructure into consideration.*	FTP_PRO.1/TLS FTP_PRO.1/WLAN	The protocols for network access are chosen for resilience and expected to meet industry standards.
Provision 5.10-1 *If telemetry data is collected from consumer IoT products, such as usage and measurement data, it should be examined for security anomalies.*	-	A requirement for the provider, App Developer, Advertiser etc. Not for the CMD itself.
Provision 5.11-1 *Users shall be provided with functionality such that all their user data can be erased from the consumer IoT device in a simple manner.*	FCS_CKM.6 FPR_PSE.1/Advertisers FPR_PSE.1/APP_Dev	
Provision 5.11-2 *The consumer should be provided with functionality on the consumer IoT device such that personal data can be deleted from associated services in a simple manner.*	-	A requirement for the provider, App Developer, Advertiser etc. Not for the CMD itself.
Provision 5.11-3 *Users should be given clear instructions on how to delete and where possible to erase their personal data from the device and associated services.*	-	A requirement for the provider, App Developer, Advertiser etc. Not for the CMD itself.
Provision 5.11-4 *Users should be provided with clear confirmation that personal data has been deleted and where possible erased from devices and associated services.*	-	A requirement for the provider, App Developer, Advertiser etc. Not for the CMD itself.
Provision 5.12-1 *Installation and maintenance of consumer IoT should involve minimal decisions by the user and should follow security best practice on usability.*	AGD_PRE.1	

ETSI EN 303 645 [i.1]	The present document	Comments
Provision 5.12-2 *The manufacturer should provide users with guidance on how to securely set up their device.*	AGD_PRE.1	
Provision 5.12-3 *The manufacturer should provide users with guidance on how to check whether their consumer IoT device is securely set up and maintained in a secure state.*	AGD_PRE.1 FPT_FLS.1	
Provision 5.13-1 *Void.*		
Provision 5.13-1A *Data input at application layer to the device via user interfaces shall be validated by the device regarding unexpected data input to prevent system manipulations and failures.*	AVA_VAN.2 (see detailed explanation after the table)	ETSI TS 103 732-4 [i.17] includes requirements related to input validation for preloaded apps that are included on the device.
Provision 5.13-1B *Data input at application layer to the device via network interfaces shall be validated by the device regarding unexpected data input to prevent system manipulations and failures.*	AVA_VAN.2 (see detailed explanation after the table)	ETSI TS 103 732-4 [i.17] includes requirements related to input validation for preloaded apps that are included on the device.
Provision 6-1 *The manufacturer shall provide consumers with clear and transparent information about what personal data is processed and for what purposes, by whom, and for how long, for each consumer IoT device and associated service. This also applies to third parties that can be involved, including advertisers.*	-	A requirement for the provider, App Developer, advertiser etc. Not for the CMD itself.
Provision 6-2 *Where personal data will be processed on the basis of consumers' consent, the consumer IoT device shall provide a means to acquire this consent in a valid way.*	-	A requirement for the provider, App Developer, advertiser etc. Not for the CMD itself.
Provision 6-3 *Void.*	-	
Provision 6-3A *Where personal data will be processed on the basis of consumers' consent, the consumer IoT device shall provide a means to withdraw this consent at any time.*		A requirement for the provider, App Developer, advertiser etc. Not for the CMD itself.
Provision 6-3B *Where personal data will be processed on the basis of consumers' consent, the consumer IoT device shall provide a means of storing information about this consent.*		A requirement for the provider, App Developer, advertiser etc. Not for the CMD itself
Provision 6-4 *If telemetry data is collected from consumer IoT products, the processing of personal data should be limited to that which is necessary for the intended functionality identified in provision 6-5.*	-	A requirement for the provider, App Developer, Advertiser etc. Not for the CMD itself.
Provision 6-5 *If telemetry data is collected from consumer IoT products, consumers shall be provided with information on what telemetry data is collected, how it is being used, by whom, and for what purposes.*	-	A requirement for the provider, App Developer, Advertiser etc. Not for the CMD itself

ETSI EN 303 645 [i.1]	The present document	Comments
Provision 6-6 *Data stored and processed on a consumer IoT device, or made available to an associated service by the consumer IoT device, for purposes identified in provision 6-1 shall be limited to that which is necessary for the purpose for which it is being collected or processed, and deleted once no longer necessary for any of the purposes identified.*		A requirement for the provider, App Developer, Advertiser etc. Not for the CMD itself.
Provision 6-7 *When the purpose of data collection from consumer IoT devices, or processing on the consumer IoT device, is solely to compute an aggregate result, the data collected should be the minimum required to compute the aggregate, the aggregation should happen as early as possible, and the retention of both collected data and the resulting aggregate should be minimized.*		A requirement for the provider, App Developer, Advertiser etc. Not for the CMD itself.
Provision 6-8 *Data anonymization technologies should be used to protect privacy during data collection, processing and storage.*	FPR_PSE.1/Advertisers FPR_PSE.1/APP_Dev	On-device, privacy protections are focused on unique identifiers assigned for the device as a whole and per app developer.

This PP requires conformance to the CC package EAL2, and EAL2 requires AVA_VAN.2 vulnerability analysis as minimum. In order to perform an independent vulnerability analysis, the TOE manufacturer is required to provide guidance documentation (AGD_OPE.1), functional specification (ADV_FSP.2), TOE design (ADV_TDS.1), security architecture description (ADV_ARC.1) and preparative procedures (AGD_PRE.1) as defined in [21], and the evaluator will review these documents, identify potential vulnerabilities, conduct penetration testing to determine that the TOE is resistant to attacks performed by an attacker possessing Basic attack potential.

Regarding Provision 5.6-1 to Provision 5.6-5 and Provision 5.13-1 in ETSI EN 303 645 [i.1] which are related to interfaces of the device, ADV_FSP.2 requires the TOE manufacturer to provide the purpose, method of use, parameters, and parameter descriptions for all interfaces of the TSF, the evaluator will evaluate whether those interfaces expose risks for Basic attack potential.

Regarding Provision 5.9-1 and Provision 5.9-2, these are requirements to avoid outages of data networks and power causing impact on the user and to design products and services that provide a level of resilience to such case. The evaluator may review the documents provided by the TOE manufacturer to check whether appropriate implementation is in place. However, these are not typical security requirements from CC perspective.

A.2 Void

Annex B (informative): Rating of a physical attack

An example of an attack scenario is an electromagnetic side-channel attack on the TSF part that performs memory encryption to discover the key that is used for memory encryption.

Table B.1

Factor and value	Rationale	Points
Expertise = Expert	A side-channel specialist is needed to mount a simple power/electro-magnetic analysis attack or differential power/electro-magnetic analysis attack. A second, proficient level person, with knowledge on the protocols used inside the TOE is not counted additionally, in accordance with footnote "a" in Table B.2 in [24]. The same applies for a third, proficient level person preparing the hardware part and mounting a coil on the part for measuring electromagnetic emanation.	6
Knowledge of the TOE = Restricted	Information on the exact key management methods and key derivation techniques is needed. Detailed sensitive design information is probably not needed.	3
Window of opportunity = Moderate	First, one needs to get hold of a TOE with a known key. Secondly, one needs to obtain (steal) the target TOE of a particular target user.	4
Equipment = Specialized	For advanced side-channel attacks usually high-end oscilloscopes with sampling rates in the Gigahertz range are used. In the particular case of an attack on a CMD, it can be sufficient to use a cheaper oscilloscope with sampling rates in the Megahertz range. For this reason, Specialized is chosen and not bespoke.	4
Elapsed time	The attacker starts out by using a TOE with a known key, so that the attacker knows when its attack is successful (when the known key is found) and find the optimal parameters. This is the most time-consuming part of the attack. This assumes that a TOE can be configured to use a known key, which may well not be the case. The time needed for the second stage, where one applies these parameters on the target TOE to discover the key takes negligible time compared to the first stage.	T
Overall rating	Sum of all points.	17+T

In the very unlikely event that both stages of the attack can be done in less than a day (so T = 0), the rating of 17 is sufficient to pass AVA_VAN.1, AVA_VAN.2, and AVA_VAN.3, but would fail for AVA_VAN.4 and AVA.VAN.5.

To pass AVA_VAN.5, the TOE would have to withstand the above attack for more than 2 months (T = 10).

Annex C:
Void

Annex D (informative): Guidance for FTP_PRO Radio Requirements

D.1 Radio Requirements Guidance Overview

D.1.1 Introduction

This annex provides guidance on how to evaluate the FTP_PRO.1 radio requirements. The FTP_PRO.1 radio requirements are focused on various industry standards that are, or may be supporting in a CMD.

The specifications for each radio comes from industry, generally in the form of some industry association, and claims of compliance to these specifications requires some type of testing to show conformance, granting access to the use of the industry logos/icons/nomenclature for the radio. The security requirements for each radio vary. Some are embedded in the general specification while others are in supplemental documents that make up the overall standard.

As these radios are designed to be interoperable with other similar devices (e.g. being able to connect to another Bluetooth device), compliance to the specification itself is critical for any CMD. Some security functionality may be optional within the specification, or there may be different iterations of the specification to which compliance may be claimed. In these cases, the requirements specify the allowed versions or detailed configurations that are expected to be supported on the CMD under evaluation. The testing to claim conformance related to these standards are likely to have tested these security requirements. Evidence of conformance therefore is likely to be sufficient to show compliance to the security requirement of this Protection Profile.

The descriptions below are to provide more context for evaluation in terms of evidence to be considered for conformance. Use of external certification testing to show the requirements have already been tested should be reviewed as to whether they are considered as sufficient for evaluation evidence. A related, but similar example, is the use of independent encryption algorithm certifications to prove the implementation is correct without requiring the evaluator to re-test the algorithm.

D.1.2 FTP_PRO.1/BT Guidance

The Bluetooth requirement specifies compliance with a newer version of the Bluetooth® core specification. These specifications cover the security rules except the duplicate device address connection. Bluetooth certification is required for a CMD to claim support for Bluetooth and utilize the icon/logo. This testing covers a wide range of functionality including security requirements.

The "*not allow more than one Bluetooth connection to the same Bluetooth device address"* rule requires the CMD to ensure that only one connection at a time is allowed to a Bluetooth device address. This is not specifically a requirement of the specification, though it is implied. This functionality of the CMD likely would need to verified.

The regeneration of ECDH key pairs has several options that are possible within the specification. Any of these is acceptable, the requirement is intended to enumerate which option has been chosen by the manufacturer.

It is important to understand that Bluetooth, by design, is backwards compatible, and as such, conformance to a recent version of the specification does not mean it is unable to connect to a device using a non-supported (e.g. older) version of the specification. This is expected behaviour, the security claims are centred around the version of the specification being supported.

D.1.3 FTP_PRO.1/WLAN Guidance

The Wi-Fi® requirement specifies compliance with one of the more recent IEEE 802.11 specifications. Generally conformance is shown through the Wi-Fi® Alliance to become Wi-Fi CERTIFIED™. Support for WPA3 is mandatory for certified devices at this point, and is sufficient for showing compliance.

The "*randomly generate a new MAC address each time it connects to a different access point*" rule is a function of the CMD and not a specific function of the Wi-Fi® certification which would be to be verified on the CMD.

Annex E (informative): Alignment with the Essential Requirements in CRA

Table E.1 shows how the CRA [i.19] essential requirements are aligned with the PP.

Table E.1

Essential Requirements	PP Requirements	Rational/comment
I.1 (1) Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks;	ASE_SPD.1 Security problem definition; ASE_OBJ.2 Security objectives; ASE_REQ.2 Derived security requirements.	**Covered**
(2) On the basis of the cybersecurity risk assessment referred to in Article 13(2) and where applicable, products with digital elements shall:		
I.1 (2)(a) be made available on the market without known exploitable vulnerabilities;	AVA_VAN.2	**Covered**
I.1 (2)(b) be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailormade product with digital elements, including the possibility to reset the product to its original state;	ADV_ARC.1 Security architecture description AGD_PRE.1 Preparative procedures FMT_SMF.1/UserControls Specification of Management Functions FPT_RCV.2 Automated recovery	**Covered** The CMD provides the user with the possibility to reset it to the factory configuration. FMT_SMF.1.1/userControls includes "*ability to perform a factory reset."* The factory configuration implements the security architecture described in ADV_ARC.1 and can be returned to the secure configuration by following the AGD_PRE.1 documentation.
I.1 (2)(c) ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them; *a-> automatic updates enabled by default with installation of updates after a timeframe* *b-> an option to disable automatic updates* *c-> notification of available updates to user* *d-> an option to temporary postpone the update to be installed when the automatic updates setting is enabled*	FDP_UPF_EXT.1/APP_Update Update check frequency FDP_UPF_EXT.1/SSW_Update Update check frequency FMT_SMF.1/APP_Update Specification of Management Functions FMT_SMF.1/SSW_Update Specification of Management Functions	**Covered** FDP_UPF_EXT.1 covers (a) and (c) by defining requirements for the frequency the TOE shall check for updates to apps, or system software and actions if an update is available. This ensures that security updates are installed within an appropriate timeframe (e.g. "an interval of no more than 1 month"). FMT_SMF.1/APP_Update and FMT_SMF.1/SSW_Update covers (b) and (d) by defining requirements for the TSF to specify if the software update (application or system software) is automatically installed, or the user is notified after the download, or the user is notified about the software update without the download. Several further actions are specified after the user selection.

Essential Requirements	PP Requirements	Rational/comment
I.1 (2)(d) ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access;	FDP_ACF.1/UserDataAsset Security attribute based access control FDP_ACC.1/UserDataAsset Subset access control FIA_AFL.1 Authentication failure handling FIA_UAU.1 Timing of authentication FIA_UID.1 Timing of identification FMT_SMF.1/UserControls Specification of Management Functions	**Covered** While user data is protected through encryption, the method for ensuring access to that data along with other TOE services is controlled through authentication. The TOE may provide services prior to authentication that are available with physical access to the TOE. These are specified in FIA_UAU.1 and FIA_UID.1. The authentication status of the device (first boot before login, locked after first login, or active on the device) can be used to further control access to the user data and device services. Overall access control to user data is handled through encryption of the data. Encryption keys are tied to successful authentication, ensuring access only once the user has been identified. FMT_SMF.1/UserControls also provides some control over what user data may be seen on the lock screen, in addition to the functions the TOE may provide.
I.1 (2)(e) protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means;	**Stored data confidentiality:** FDP_ACF.1/UserDataAsset Security attribute based access control FDP_ACC.1/UserDataAsset Subset access control FPT_PHP.3 Resistance to physical attack **Transmitted data confidentiality:** FTP_PRO.1 (ALL) **Supporting cryptographic mechanisms:** FCS_CKM.1 (ALL) FCS_CKM.5 Cryptographic key derivation FCS_COP.1 (ALL) FCS_RBG.1 Random bit generation FCS_RBG.3 Random bit generation (internal seeding – single source)	**Covered** FDP_ACC.1/UserDataAsset & FDP_ACF.1/UserDataAsset define the conditions under which the CMD decrypts the User Data Assets based on their classification; this requires that the User Data Assets are encrypted on the CMD. FPT_PHP.3 provides additional protection for keys against physical attacks. The confidentiality of the communication is defined within the TOE scope for Bluetooth, TLS and WLAN. Cryptographic mechanisms supporting these capabilities are covering the state of the art.

Essential Requirements	PP Requirements	Rational/comment
I.1 (2)(f) protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions;	**Stored data integrity:** FPT_PHP.3 Resistance to physical attack FDP_SDI.1 **Transmitted data integrity:** FTP_PRO.1 (ALL) **Supporting cryptographic mechanisms:** FCS_CKM.1 (ALL) FCS_CKM.5 Cryptographic key derivation FCS_COP.1 (ALL) FCS_RBG.1 Random bit generation FCS_RBG.3 Random bit generation (internal seeding – single source)	**Covered** The risk assessment/threat model for the CMD focuses on ensuring the integrity of critical security parameters (such as encryption keys), protecting against physical attack. Mass user data storage is scoped to be protected by confidentiality, with the integrity provided implicitly by the protection of the encryption keys. For stored data, FPT_PHP.3 protects the integrity of the keys used to encrypt the user data. This provides indirect integrity by ensuring that the keys used to encrypt user data are always verified. The CMD monitors user data stored to check for integrity errors. Data corruption at the CMD level (i.e. for mass storage) is most likely to result in the CMD, or the application not working properly. Individual applications can utilize the CMD services to provide integrity within its own context. External storage devices that can be removed from the CMD are not in scope of the evaluation. The integrity of the communication is defined within the TOE scope for Bluetooth, TLS and WLAN.
I.1 (2)(g) process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (minimisation of data);	ADV_PDM_EXT.1 Processed Data Minimisation FDP_ACC.2/SSW_Update Complete access control FDP_ACF.1/SSW_Update Security attribute based access control	**Covered** The main OS of the CMD is covered for data minimization within the scope of the TOE by minimizing the data collected during system software updates. Apps are individually covered under requirements in ETSI TS 103 732-4 [i.17]. The apps on the device are not evaluated for their capabilities, including data usage, but for permissions they are assigned and the best coding practices for apps, and possible vulnerabilities associated with poor choices in app design. The functionality of those apps are not covered and are subject to their own minimization requirements under CRA. Preloaded and preinstalled apps would cover this under in ETSI TS 103 732-4 [i.17].

Essential Requirements	PP Requirements	Rational/comment
I.1 (2)(h) protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks;	FPT_FLS.1 Failure with preservation of secure state FPT_TST.1 TSF testing FPT_RCV.2 Automated recovery	**Covered** The risk assessment/threat model for the CMD is focused on protecting user data from disclosure, especially user data stored on the device that may no longer be in the possession of the owner. FPT_TST.1 verifies the integrity of the main OS and other core components of the CMD to ensure they are functioning properly and have not been tampered with. In the case of an integrity failure, the device fails into a secure state where al user data is still protected (encrypted) in FPT_FLS.1. Depending on the type of integrity failure, automated recovery (FPT_RCV.2) may provide automatic recovery of the system to resume functioning or may provide a state for the user to perform a clean return to the initial CMD setup state, which still preserves the data security by removing the encrypted data while returning the CMD to an operational state.
I.1 (2)(i) minimise the negative impact by the products themselves or connected devices on the availability of services provided by other devices or networks;		**Not Applicable** The CMD does not provide any network services to other devices. In the rare case where Wi-Fi tethering is provided it relies on the cellular modem communication that is out of the scope of the TOE and is designed for limited connections.
I.1 (2)(j) be designed, developed and produced to limit attack surfaces, including external interfaces;	ADV_ARC.1 Security architecture description ADV_FSP.2 Security-enforcing functional specification ADV_TDS.1 Basic design AGD_OPE.1 Operational user guidance AVA_VAN.2 Vulnerability analysis	**Covered**
I.1 (2)(k) be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques;	ADV_ARC.1 Security architecture description ADV_FSP.2 Security-enforcing functional specification. ADV_TDS.1 Basic design FPT_FLS.1 Failure with preservation of secure state FPT_RCV.2 Automated recovery	**Covered**
I.1 (2)(l) provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user;		**Not Applicable** On device auditing for consumer devices is not appropriate for several reasons. First, consumers are unlikely to be able to understand the audit events for meaningful interpretation. Second, having the records only locally means that if the device is not in their possession, they would be unable to use the logs anyway. For the purposes of the CMD, the expectation is that any logging is handled through accounts on the device. As these are off the device, they are outside the specific scope of the evaluation.

Essential Requirements	PP Requirements	Rational/comment
I.1 (2)(m) provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner.	FCS_CKM.6 Timing and event of cryptographic key destruction FMT_SMF.1/UserControls Specification of Management Functions	**Covered** For data removal, FMT_SMF.1/UserControls provides the user with the ability to return the TOE to the initial setup state. This feature relies on FCS_CKM.6 to provide a secure method of doing this to ensure that previously stored user data is not accessible after the reset. For data transfer, FMT_SMF.1/UserControls provides the capability to perform a data transfer through several methods to a new device (or restore an existing one after a reset).
I.2 (1) identify and document vulnerabilities and components contained in products with digital elements, including by drawing up a software bill of materials in a commonly used and machine-readable format covering at the very least the top-level dependencies of the products;	ALC_CMC.2 Use of the CM system ALC_CMS.3 Implementation representation CM coverage ALC_FLR.3 Systematic flaw remediation	**Covered** ALC_CMS.2 provides that the components of the TOE need to be known and specified. This does not mandate a format or a description of dependencies, the specific format can be determined by the developer according to their development processes. ALC_CMS.3 requires that the TOE developer track all parts of the code they use for the TOE, including third party components as part of the CMS. ALC_FLR.3 provides flaw remediation across the whole device, and includes all components in the CMS.
I.2 (2) in relation to the risks posed to products with digital elements, address and remediate vulnerabilities without delay, including by providing security updates; where technically feasible, new security updates shall be provided separately from functionality updates;	ALC_FLR.3 Systematic flaw remediation	**Covered** ALC_FLR.3 requires the TOE developer to specify the types of updates they provide for devices. The specific breakdown of how updates are handled is left to the TOE developer to document, including whether or not functional vs security updates are supported. The EUCC mandates that any change to the product certified generate an update of the certificate, maintained or updated. The impact analysis report for the maintenance update will be performed regardless of the type of update.
I.2 (3) apply effective and regular tests and reviews of the security of the product with digital elements;		**Covered** The product certified according to EUCC is obligated to provide regular updates and surveillance mechanism of the EUCC implies the requirement is fulfilled as any change to the assurance of the certificate will trigger actions from the developer and the CAB, including the testing.

Essential Requirements	PP Requirements	Rational/comment
I.2 (4) once a security update has been made available, share and publicly disclose information about fixed vulnerabilities, including a description of the vulnerabilities, information allowing users to identify the product with digital elements affected, the impacts of the vulnerabilities, their severity and clear and accessible information helping users to remediate the vulnerabilities; in duly justified cases, where manufacturers consider the security risks of publication to outweigh the security benefits, they may delay making public information regarding a fixed vulnerability until after users have been given the possibility to apply the relevant patch;	ALC_FLR.3 Systematic flaw remediation	**Covered**
I.2 (5) put in place and enforce a policy on coordinated vulnerability disclosure;	ALC_FLR.3 Systematic flaw remediation	**Covered** ALC_FLR.3 supports responsible disclosure as part of the vulnerability management policy. As part of an EUCC evaluation, the vendor is required to provide this information, and it would be expected to be included as part of the ALC_FLR.3 documentation.
I.2 (6) take measures to facilitate the sharing of information about potential vulnerabilities in their product with digital elements as well as in third party components contained in that product, including by providing a contact address for the reporting of the vulnerabilities discovered in the product with digital elements;	ALC_FLR.3 Systematic flaw remediation	**Covered**
I.2 (7) provide for mechanisms to securely distribute updates for products with digital elements to ensure that vulnerabilities are fixed or mitigated in a timely manner and, where applicable for security updates, in an automatic manner;	ALC_FLR.3 Systematic flaw remediation	**Covered**
I.2 (8) ensure that, where security updates are available to address identified security issues, they are disseminated without delay and, unless otherwise agreed between a manufacturer and a business user in relation to a tailor-made product with digital elements, free of charge, accompanied by advisory messages providing users with the relevant information, including on potential action to be taken.	ALC_FLR.3 Systematic flaw remediation	**Covered** The extended component defined by ENISA about the distinction between security and functional updates is not applicable for the CMD scenario where in several cases the way to remediate a vulnerability is a mix between a security and a functional update The commercial aspects of the ESR is not applicable to the CMDPP.

History

Version	Date	Status
V1.1.1	November 2021	Publication as ETSI TS 102 732
V2.1.1	October 2023	Publication
V2.1.2	November 2023	Publication
V3.1.1	September 2026	Publication